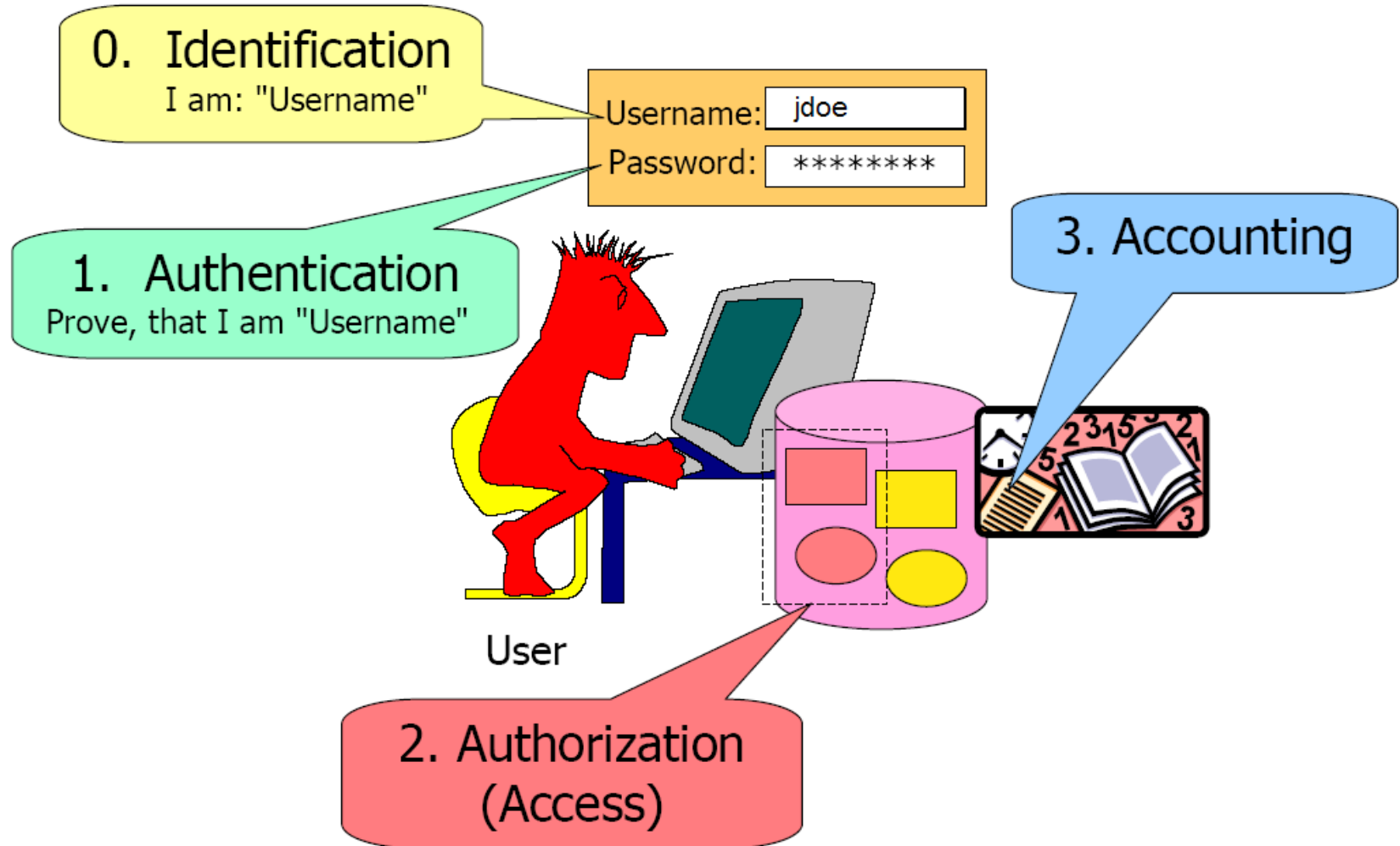


1. Protocoale de Autentificare



Authentication, Authorization, Accounting (AAA)



Autentificarea utilizatorilor

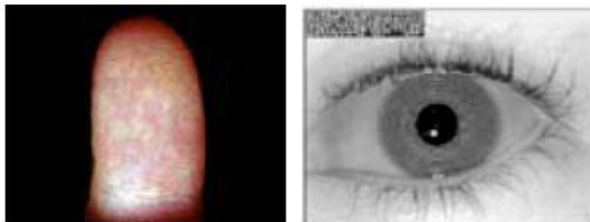
- Ceea ce utilizatorul cunoaște (parolă, PIN)

Username:
Password:

- Ceea ce utilizatorul deține (certificat digital, token)



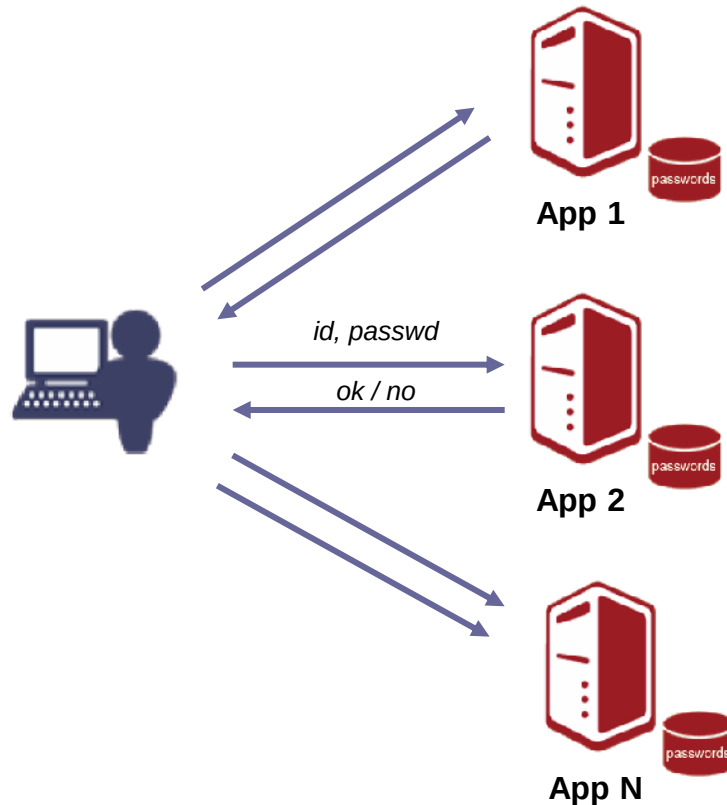
- Ceea ce utilizatorul este (amprenta, voce)



- Autentificarea sigură a utilizatorilor presupune combinarea a cel puțin doi factori!

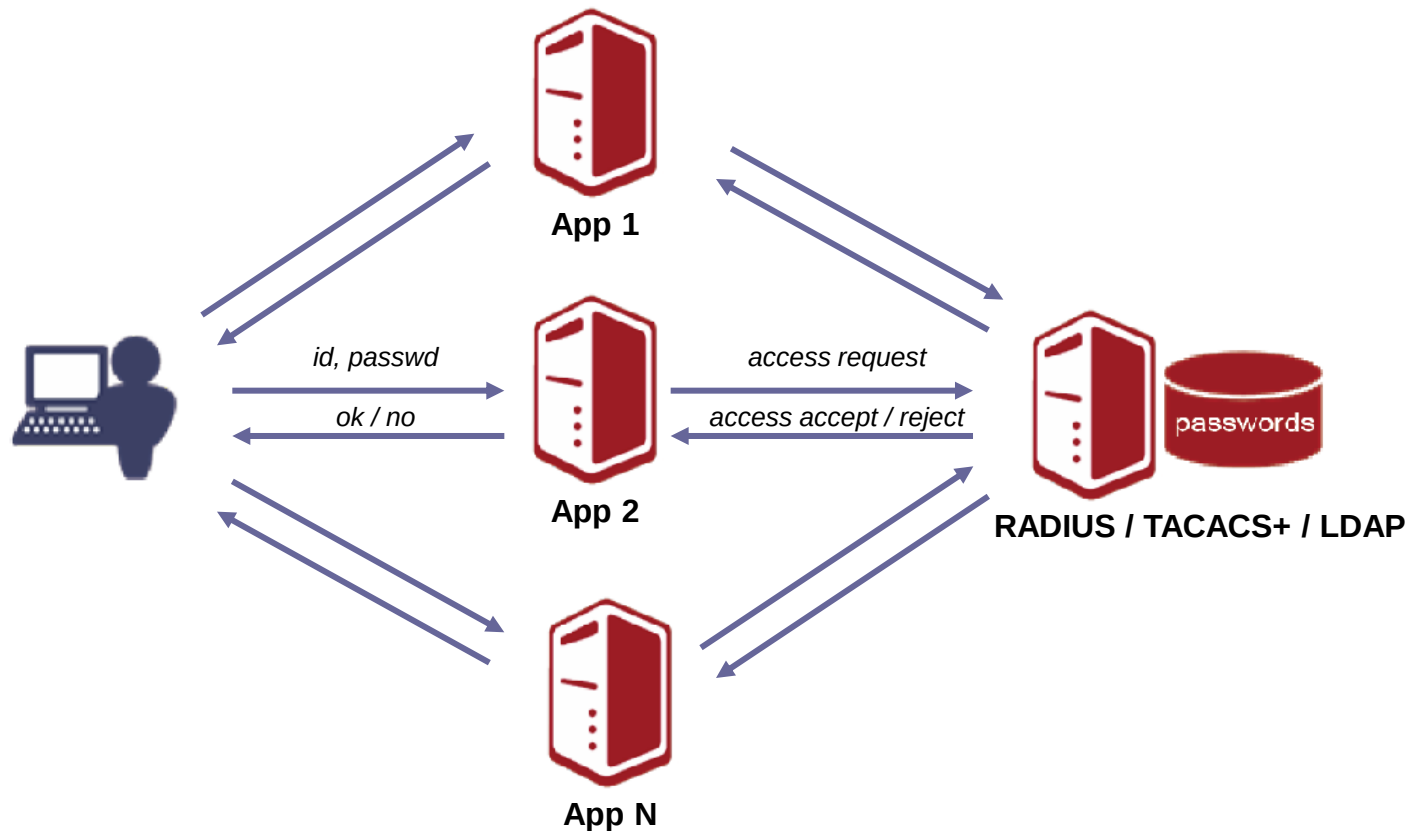
Autentificare directă

- Fiecare sistem are o bază de date proprie pentru autentificarea utilizatorilor
- Ok, pentru site-uri cu un număr mic de utilizatori / aplicații



Autentificare indirectă

- Bază de date centrală folosită în comun de mai multe sisteme
 - RADIUS, TACACS+, LDAP
- Management centralizat al utilizatorilor

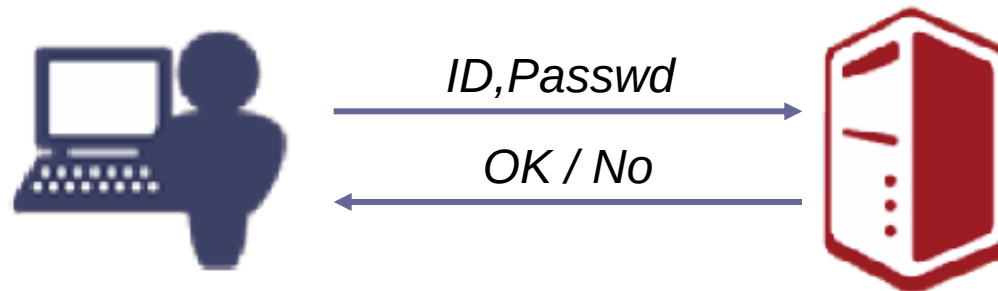


Protocoloale de autentificare

- Password Authentication Procedure (PAP)
- Challenge-Handshake Authentication Protocol (CHAP)
- Windows NT LAN Manager (NTLM)
- Kerberos
- Certificate digitale
- Generatoare de parole de unică folosință
- Biometrice

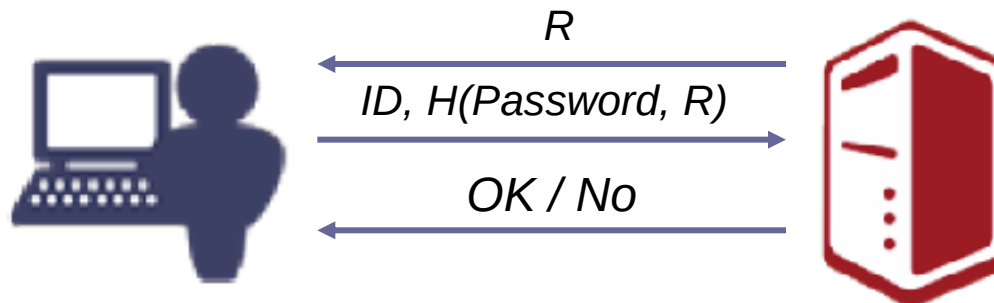
PAP

- Transmiterea în clar a username-ului și parolei
- IETF RFC 1334



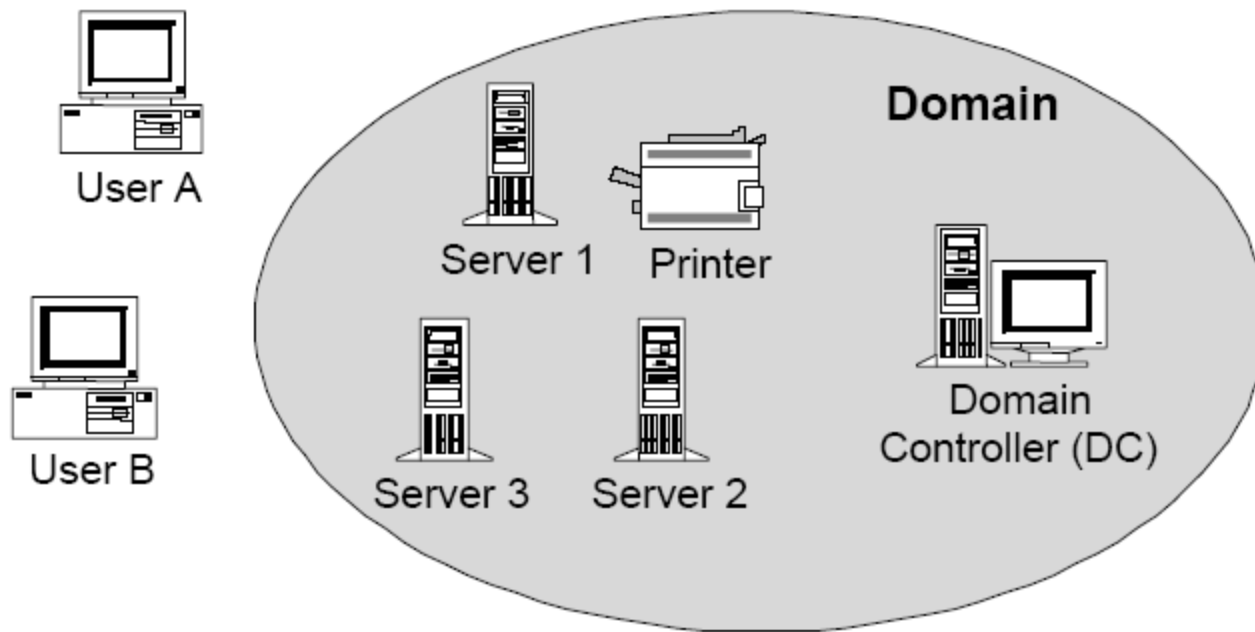
CHAP

- Protocol în trei pași:
 - Provocare (Challenge)
 - Răspuns
 - Succes / Failure
- Parola nu circulă niciodată în clar prin rețea
- Valoarea aleatoare (provocarea) trebuie să fie de fiecare dată alta pentru a evita atacurile prin reluare
- IETF RFC 1994

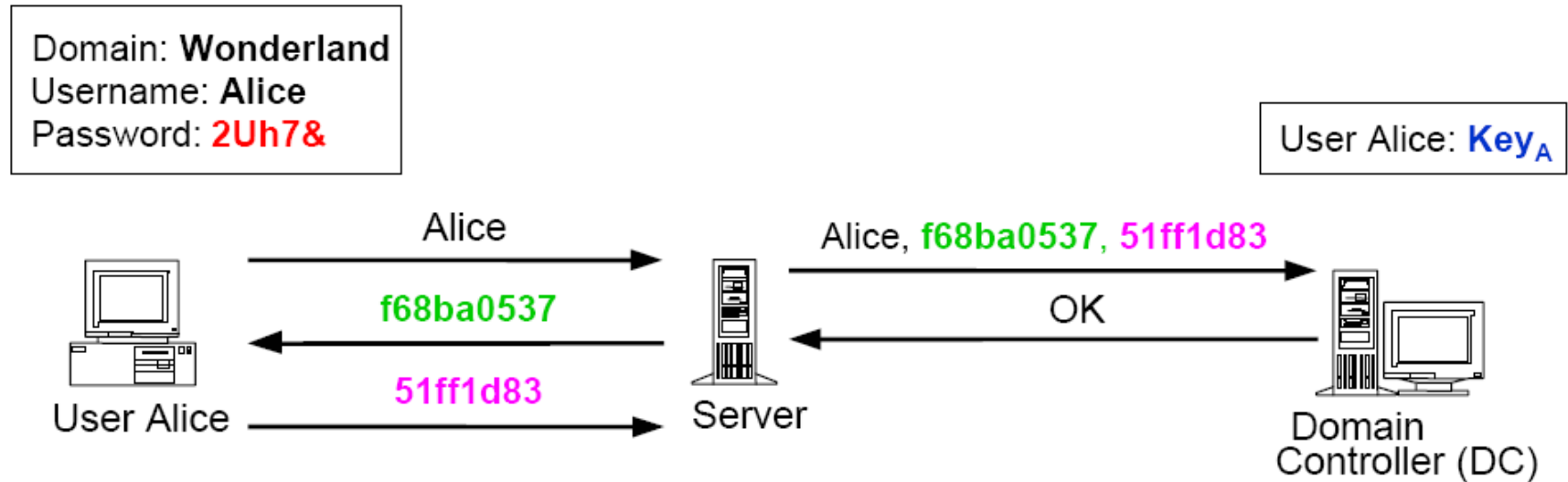


- **Autentificare în Domenii Windows**
- **Un domeniu este o colecție de servicii (E-mail, File Sharing, Printing, etc) administrate prin intermediul unui Domain Controller (DC)**
- **Administrare centralizată:**
 - Fiecare utilizator are un singur cont pentru un domeniu, gestionat de către Domain Controller (DC)
 - Nu este nevoie ca utilizatorii să aibă conturi pe fiecare server din domeniu
- **Flexibilitate ridicată:**
 - Administrare la nivel de grup
 - Domenii multiple (relații de încredere între domenii)
- **Toată lumea trebuie să aibă încredere în Domain Controller**

NTLM (cont.)



Protocol NTLM



$H(2Uh7\&) = Key_A$
 $E(f68ba0537, Key_A) = 51ff1d83$

Challenge: f68ba0537

$E(f68ba0537, Key_A) = 51ff1d83$
Comparison with 51ff1d83 – ok?

H: Hash function
 $E(x, k)$: Encryption of x with key k

Securitatea NTLM

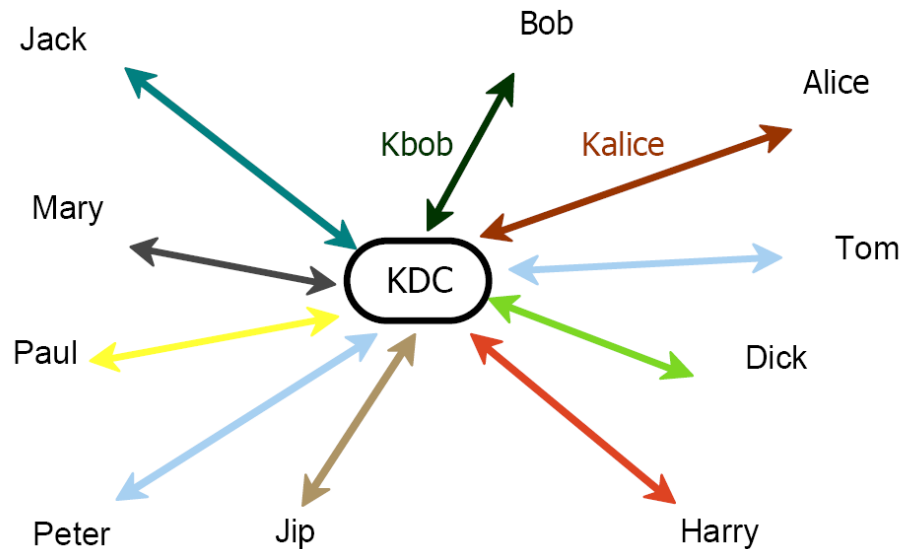
- **Avantaje:**
 - Parola utilizatorului nu este niciodată transmisă în clar
 - Parola utilizatorului este cunoscută numai de către DC
 - Protocol simplu și eficient dacă de folosesc parole sigure
- **Dezavantaje:**
 - Protocolul de autentificare trebuie repetat pentru fiecare server în parte
 - DC reprezintă un element critic (instalare Backup Domain Controller)
 - Parolele slabe sau scurte pot fi sparte offline prin atacuri de tip dicționar

Kerberos



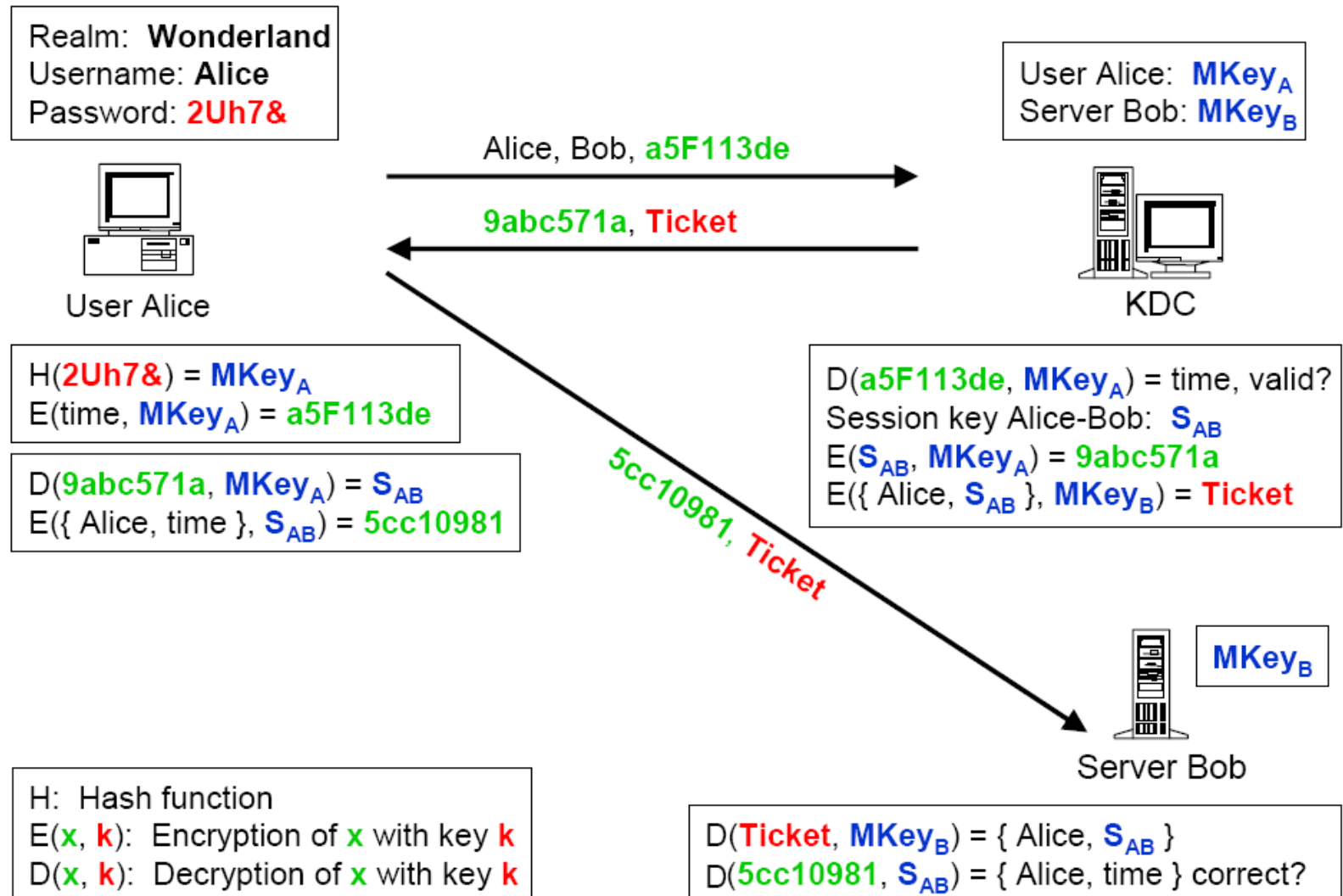
- Dezvoltat în 1983 în cadrul proiectului Athena de la Massachusetts Institute of Technology (MIT)
 - <http://web.mit.edu/kerberos/www/>
- Autentificarea în rețele TCP/IP bazate pe sisteme Unix
- Algoritmi criptografici simetrici (DES)
- Se bazează pe serviciile de mediere oferite de un terț de încredere (KDC - Key Distribution Center)
- Derivat din schema Needham și Schroeder
- Autentificare mutuală între entități
- Versiunea curentă v5 (IETF RFC 1510, 1993).
- Microsoft a adoptat Kerberos începând cu Windows 2000
 - Windows folosește o versiune extinsă a protocolului Kerberos (suport pentru certificate digitale stocate pe smart carduri)

Kerberos KDC



- **Key Distribution Center (KDC)**
- **Fiecare entitate (principal) are câte o cheie secretă master pe care o înregistrează la KDC**
 - cheile master ale utilizatorilor sunt derivate din parola de login
- **Fiecare acces securizat este “mediat” prin intermediul unor tickete Kerberos**

Protocolul Kerberos Simplificat

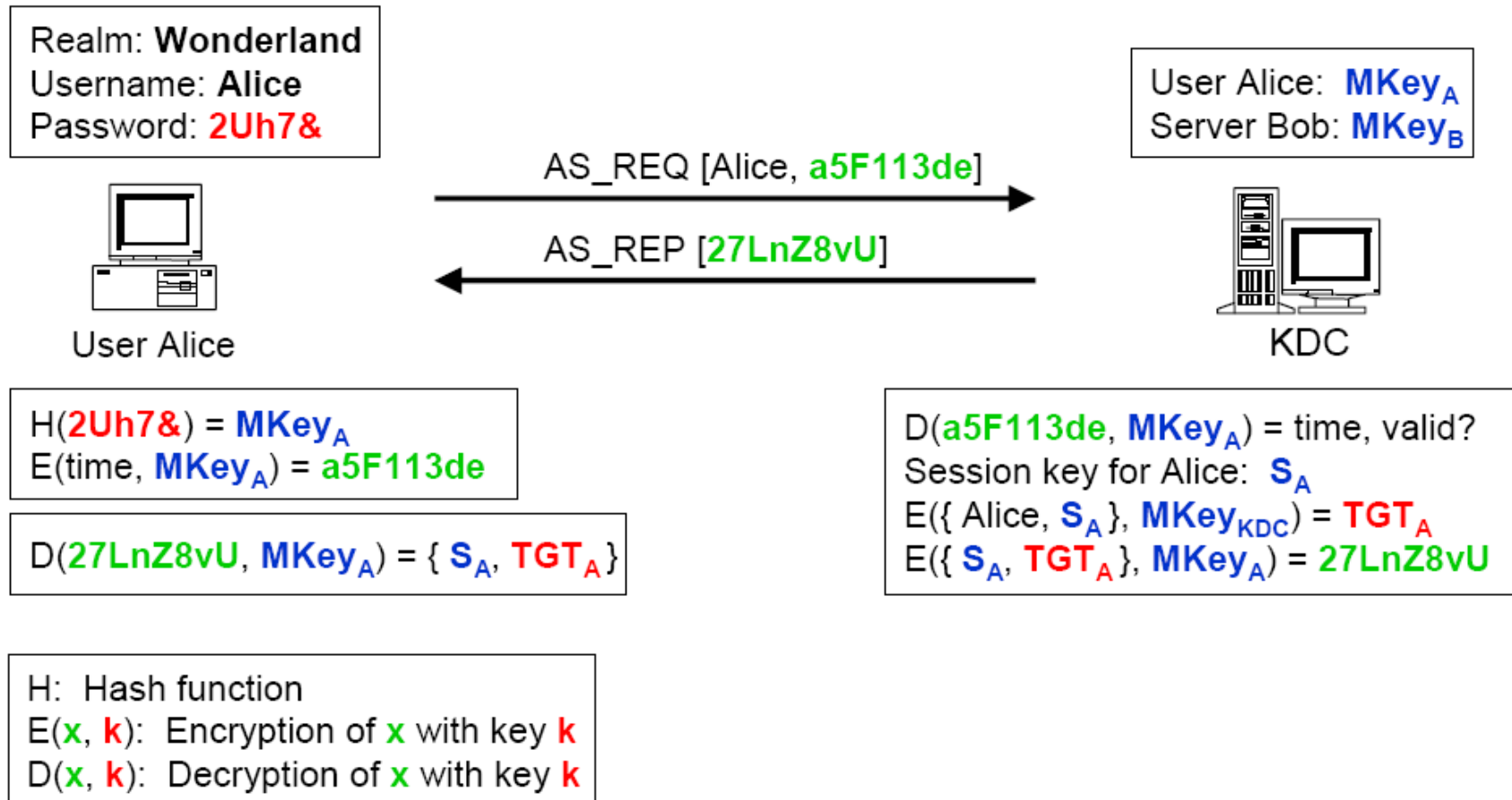


Protocolul Kerberos Simplificat (cont.)

- **Dezavantaje:**
 - cheia master a utilizatorului trebuie folosită de fiecare dată când se accesează un server și trebuie emis un nou ticket de către KDC
 - utilizatorul trebuie să introducă de fiecare dată parola atunci când se trimite o cerere de emitere ticket către KDC sau cheia master a utilizatorului trebuie ținută într-o memorie temporală (risc de securitate!)
- **Soluție:** emiterea unei chei de sesiune și a unui ticket special de către KDC (Ticket-Granting Ticket) având un timp de viață mai lung (8-24 ore)
 - utilizatorul trebuie să introducă mai rar parola

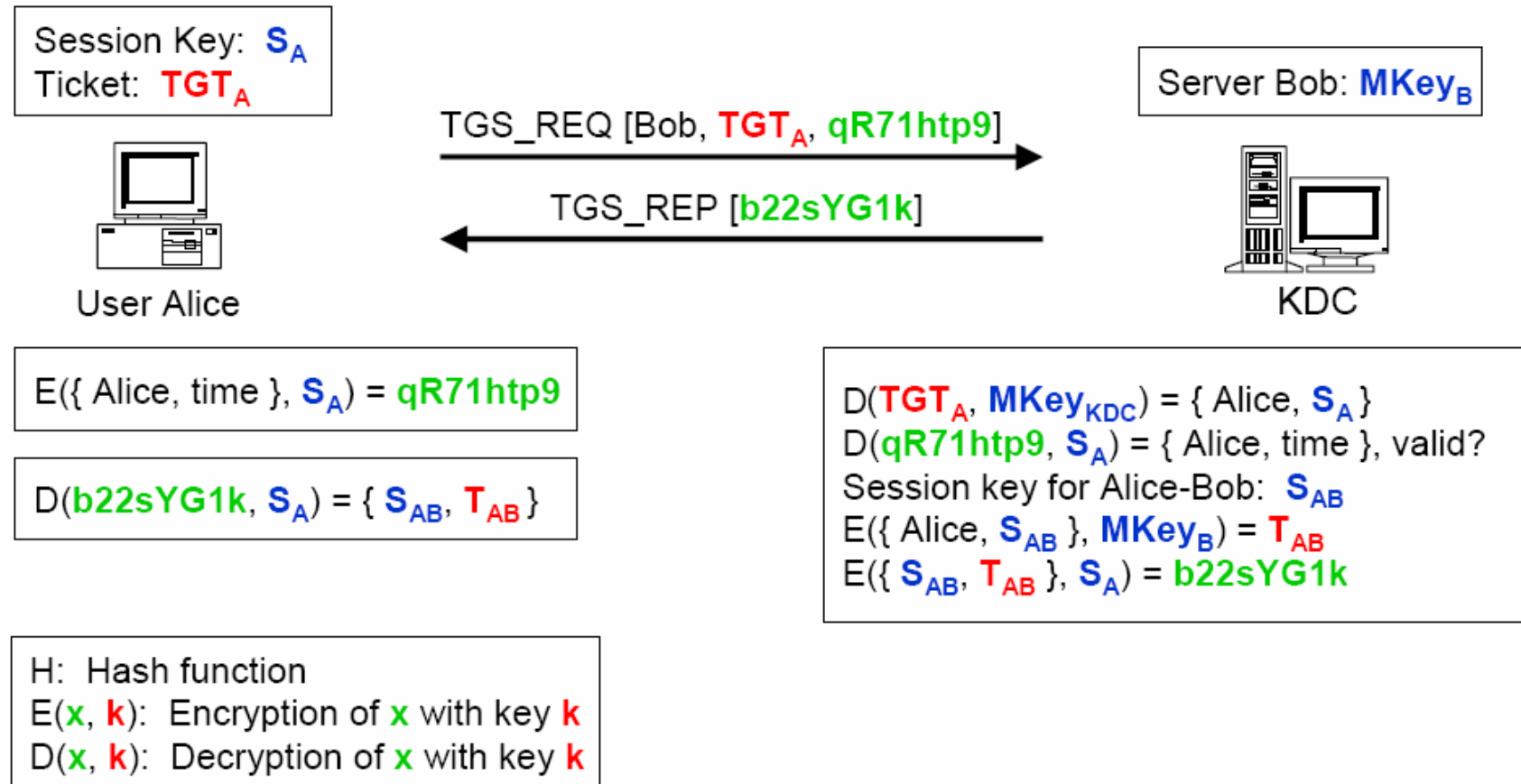
Protocolul Kerberos

Autentificarea Inițială



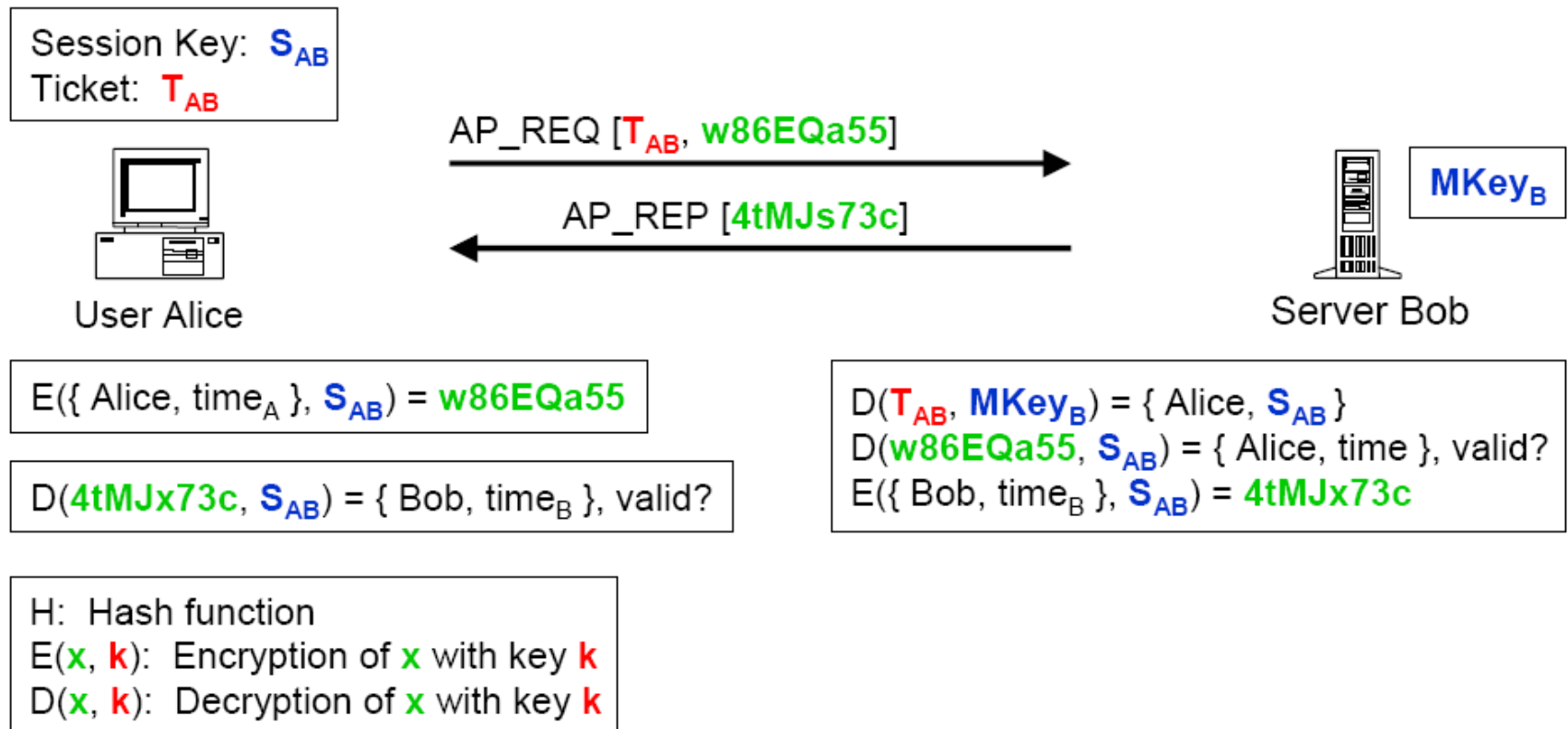
Protocolul Kerberos

Obținere Ticket de Acces



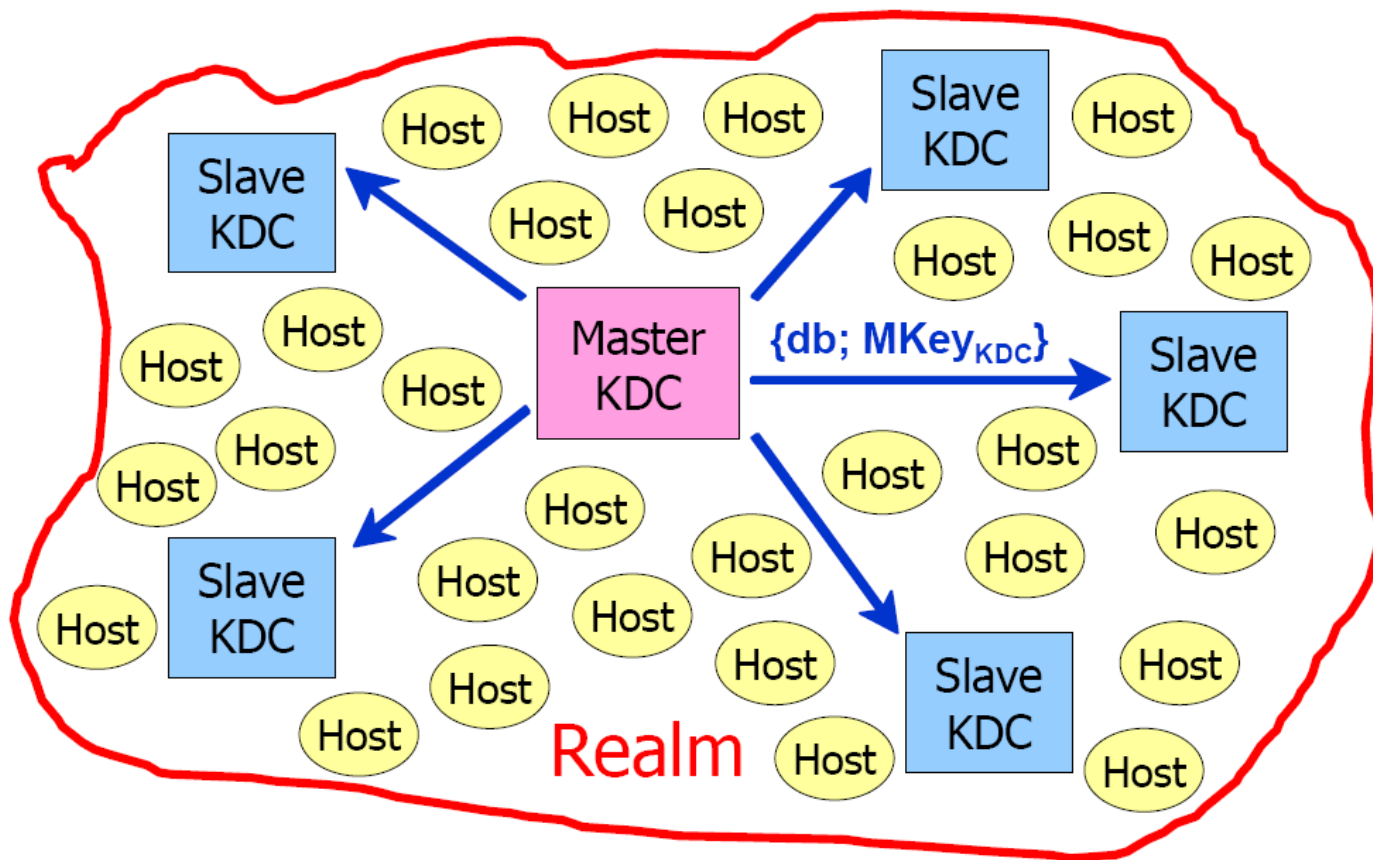
Protocolul Kerberos

Autentificarea Client / Server



Kerberos

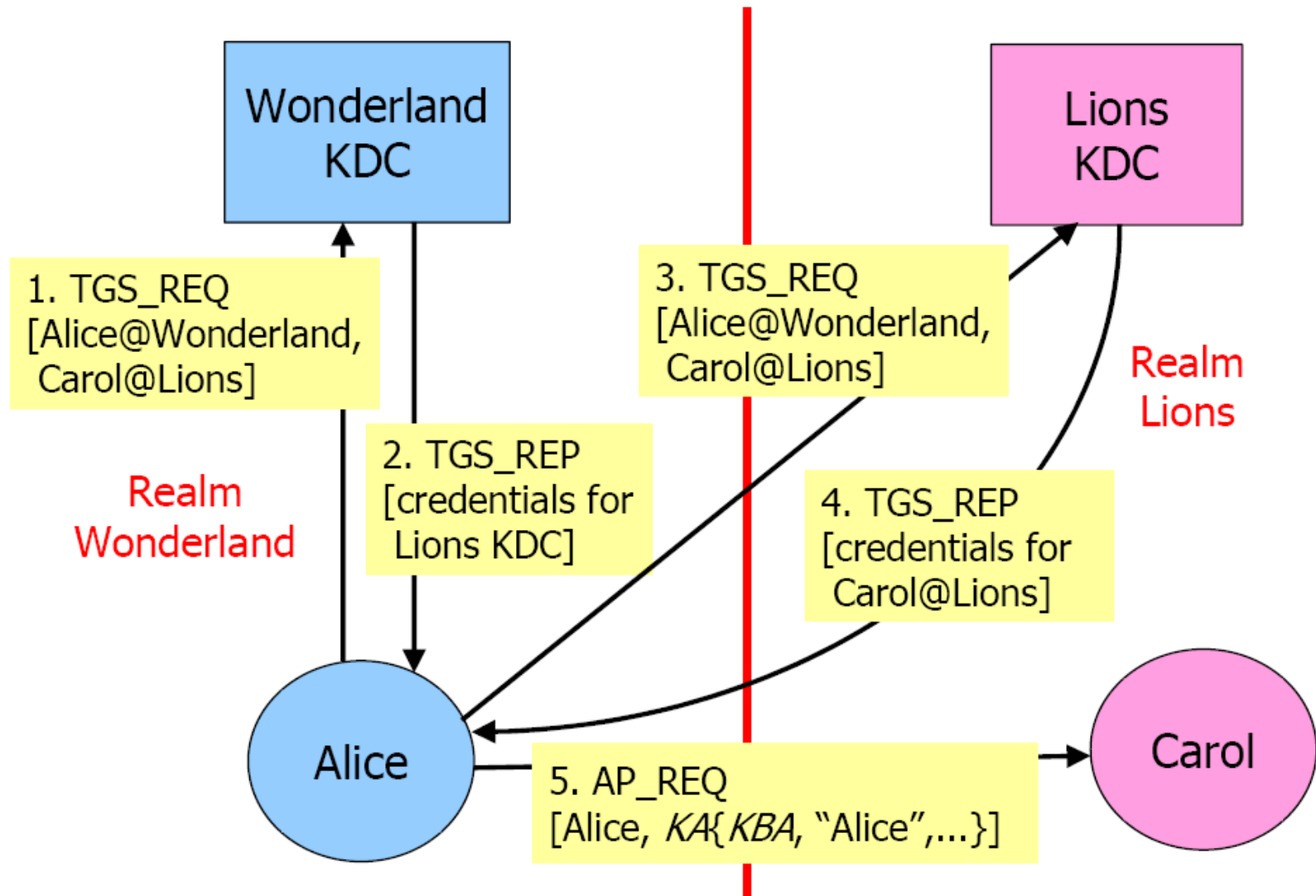
Replicarea KDC



- Baza de date a KDC Master este transferată periodic către KDC Slave
- Bazele de date ale KDC Slave sunt read-only

Kerberos

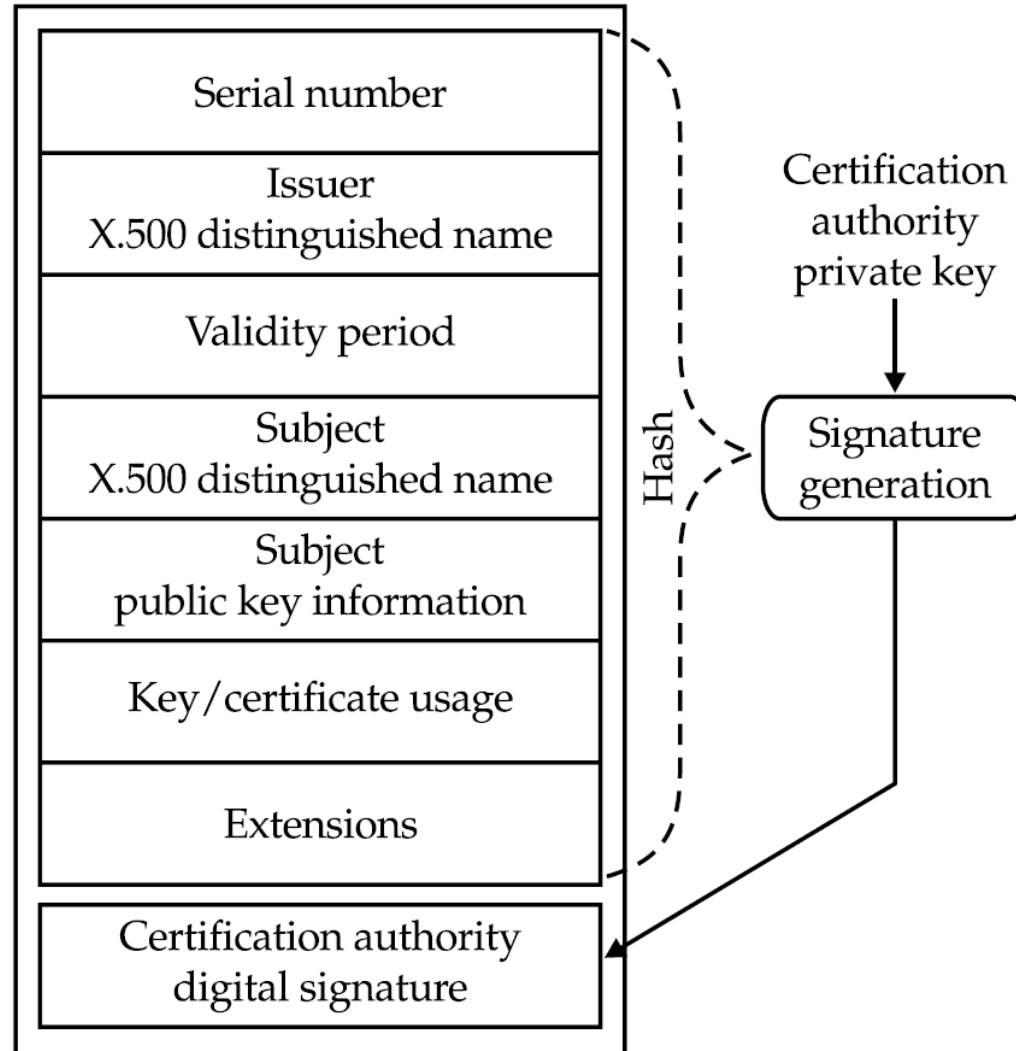
Autentificarea între realm-uri



Autentificarea cu Certificate Digitale

- **ITU-T Recommendation X.509: Information Technology – Open Systems Interconnection – The Directory: Authentication Framework**
- **Infrastructuri de Chei Publice (PKI)**
 - **Autoritate de Certificare (CA) = terț de încredere care garantează faptul că o cheie aparține unei entități**
 - **certificate digitale de chei publice**

Certificate digitale



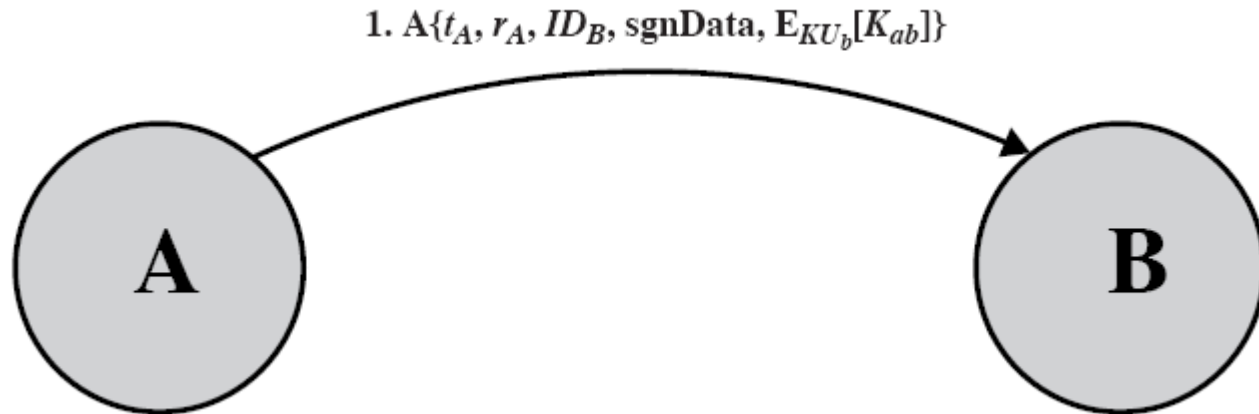
Certificate digitale (cont.)

- **Subject X.500 Name**
 - C = RO, O = MTA, CN = Ion Bica
- **Subject Alternative Name**
 - Adresa e-mail (rfc822Name)
 - Windows username (UPN)
- **Subject Public Key**
- **Key Usage**
 - digitalSignature (short term signatures)
 - nonRepudiation (long term signatures)
 - keyEncipherment
 - keyAgreement
- **Extended Key Usage**
 - serverAuthentication
 - clientAuthentication
 - codeSigning
 - emailProtection
- **CRL Distribution Points**

Protocoloale de autentificare X.509

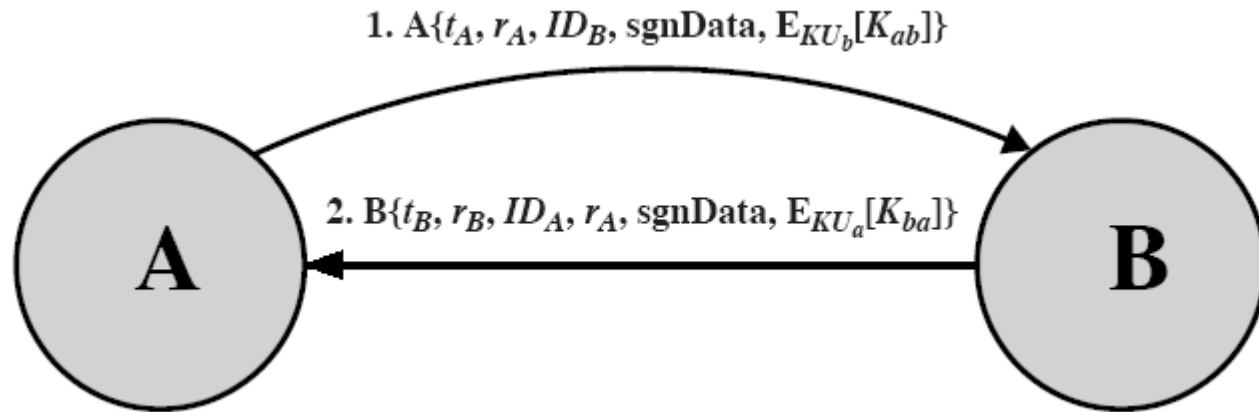
- Autentificarea se realizează făcând dovada posesiei cheii private asociate cheii publice din certificat
 - semnarea digitală a unor date arbitrare
- Certificatul digital în sine nu constituie un factor de autentificare (este public și poate fi obținut de oricine!)
 - certificatul se folosește doar pentru validarea datelor semnate de entitatea ce urmează a fi autentificată
- Protocoloale de autentificare X.509
 - One-way authentication
 - Two-way authentication
 - Three-way authentication

One-way authentication



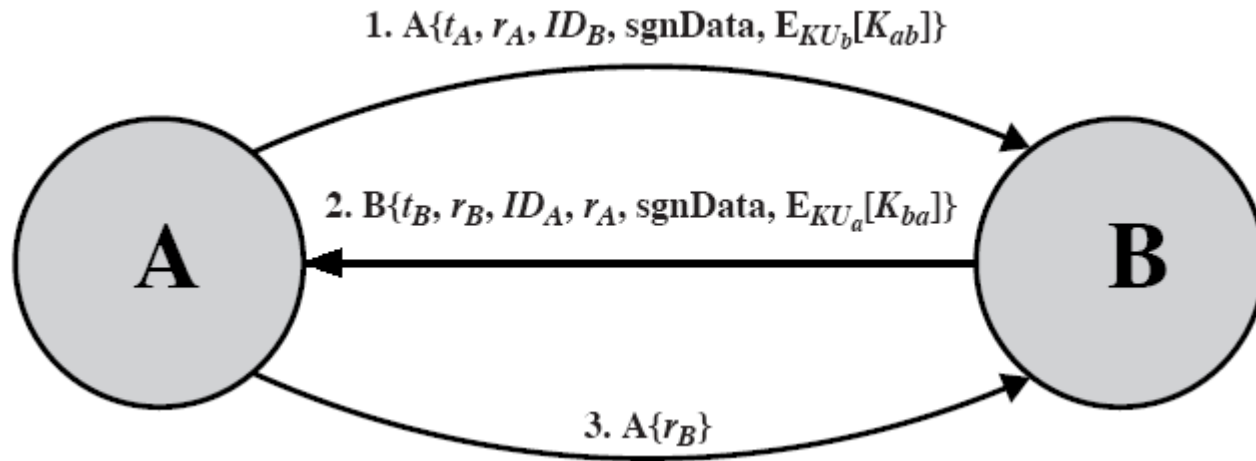
- Un singur schimb de mesaje
- Protocolul asigură:
 - autentificarea lui A la B
 - integritatea și originalitatea datelor (mesajul nu a fost trimis de mai multe ori)

Two-way authentication



- Două schimburi de mesaje
- Protocolul asigură în plus:
 - autentificarea lui B la A
 - integritatea și originalitatea răspunsului

Three-way authentication

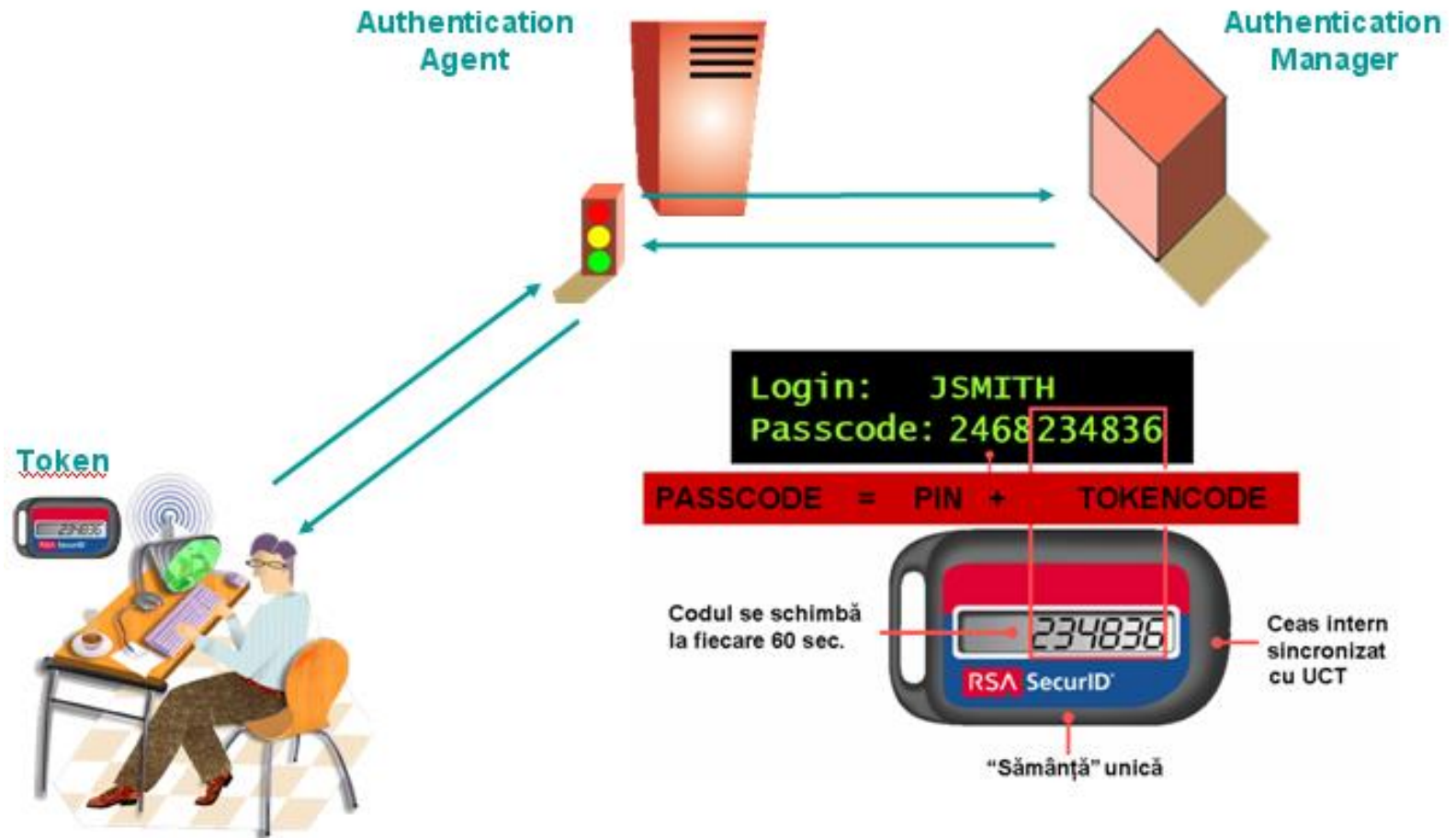


- Trei schimburi de mesaje
- Protocolul asigură în plus:
 - evitarea atacurilor prin reluare în cazul în care ceasurile celor două sisteme nu se pot sincroniza

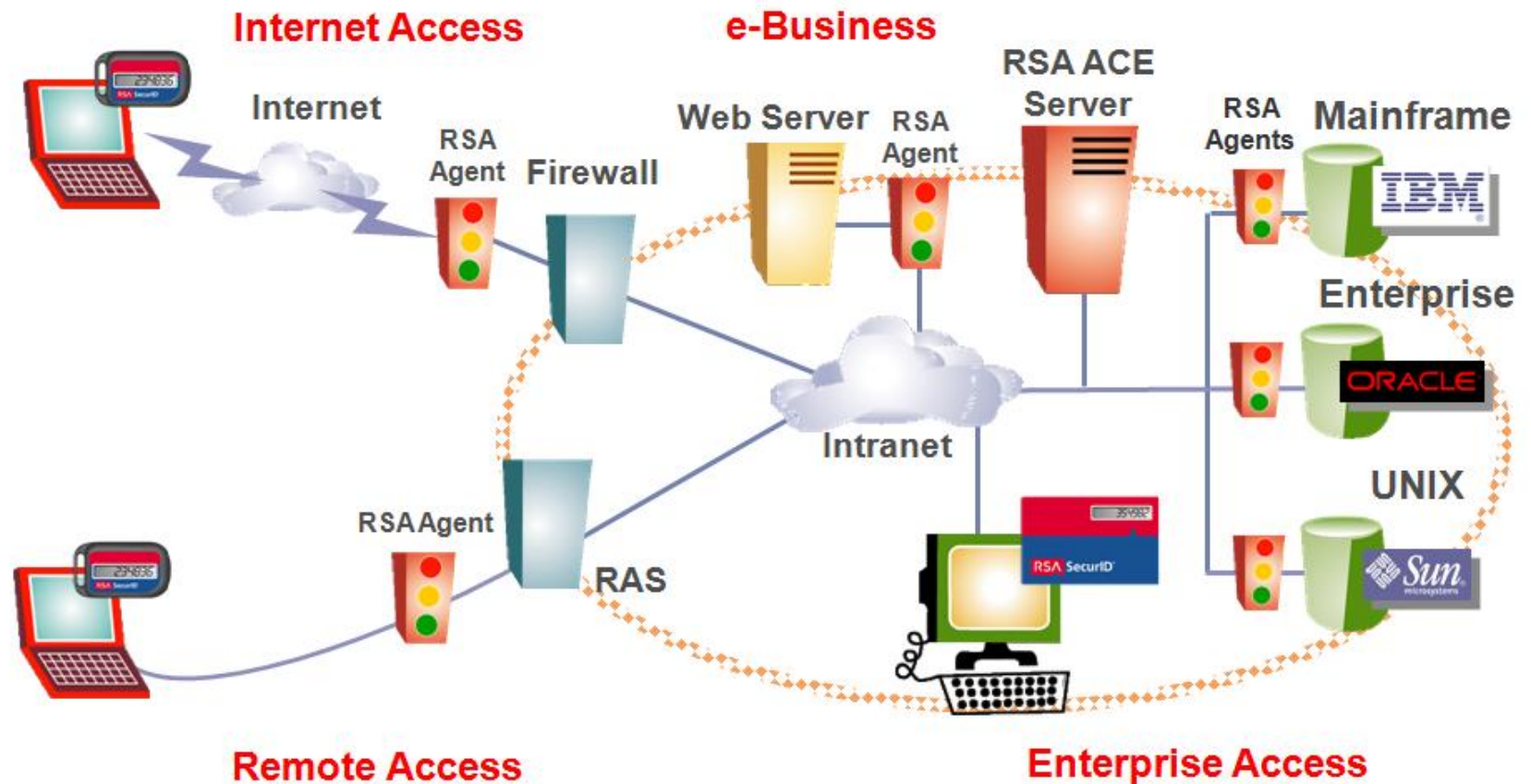
Generatoare de parole de unică folosință

- **Parolele sunt vulnerabile la o serie de atacuri**
 - pot fi interceptate
 - pot fi ghicite sau sparte prin încercări repetate
- **Soluția: parole de unică folosință**
 - nu pot fi refolosite dacă sunt interceptate
 - RSA SecurID
 - VASCO DIGIPASS
 - Gemalto/SafeNet eToken
 - Google Authenticator

RSA SecurID

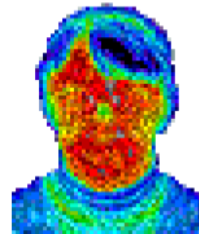
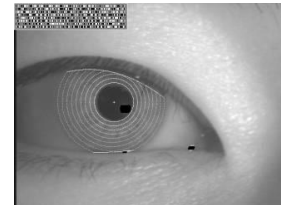
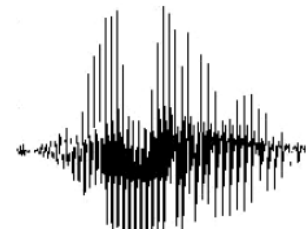


RSA SecurID (cont.)

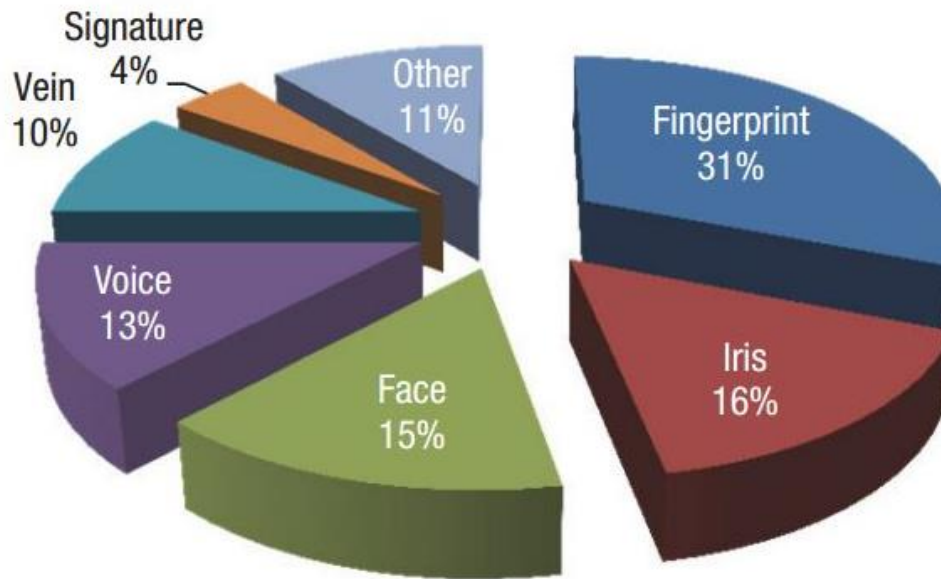


Metode Biometrice

- Amprenta
- Voce
- Iris
- Geometria feței
- Geometria mâinii
- Semnătura olografă
- Scanarea retinei
- Amprenta termică a feței
- ADN
- ...

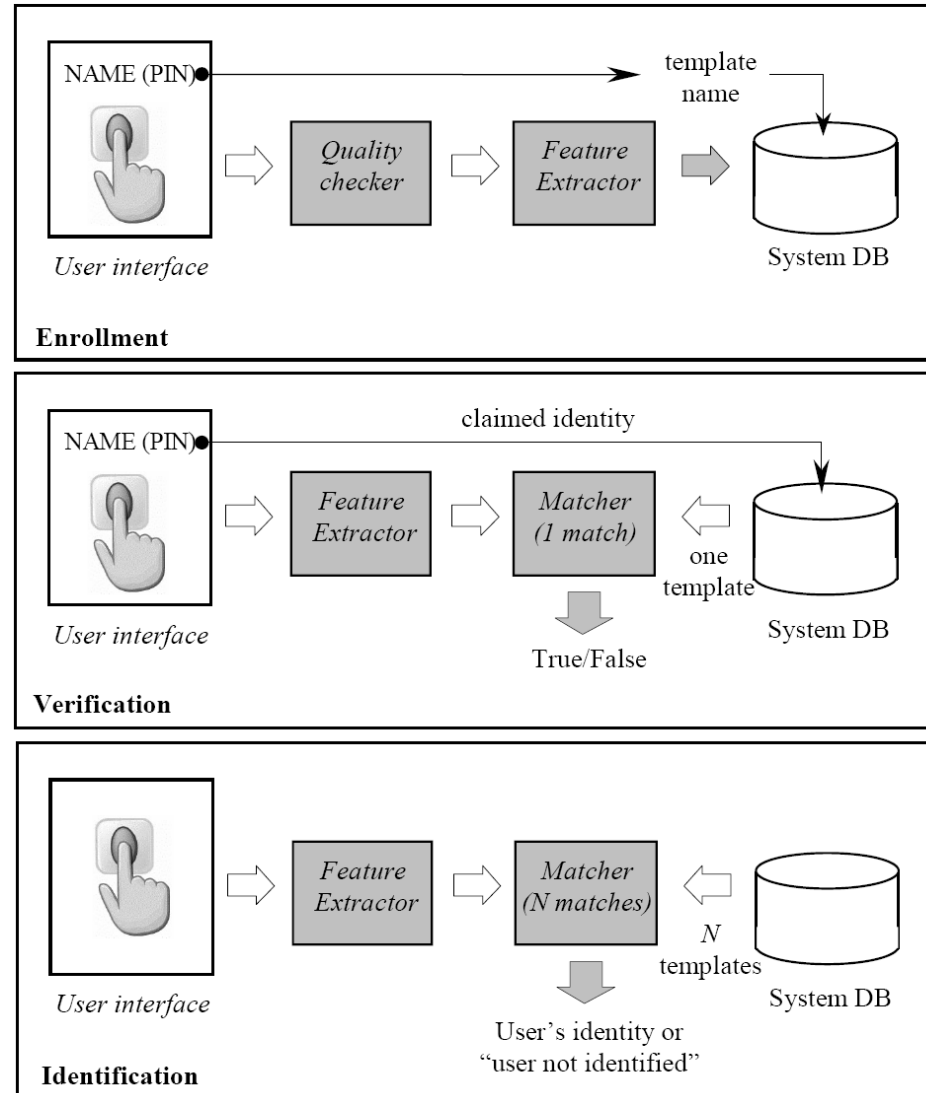


Metode Biometrice (cont.)

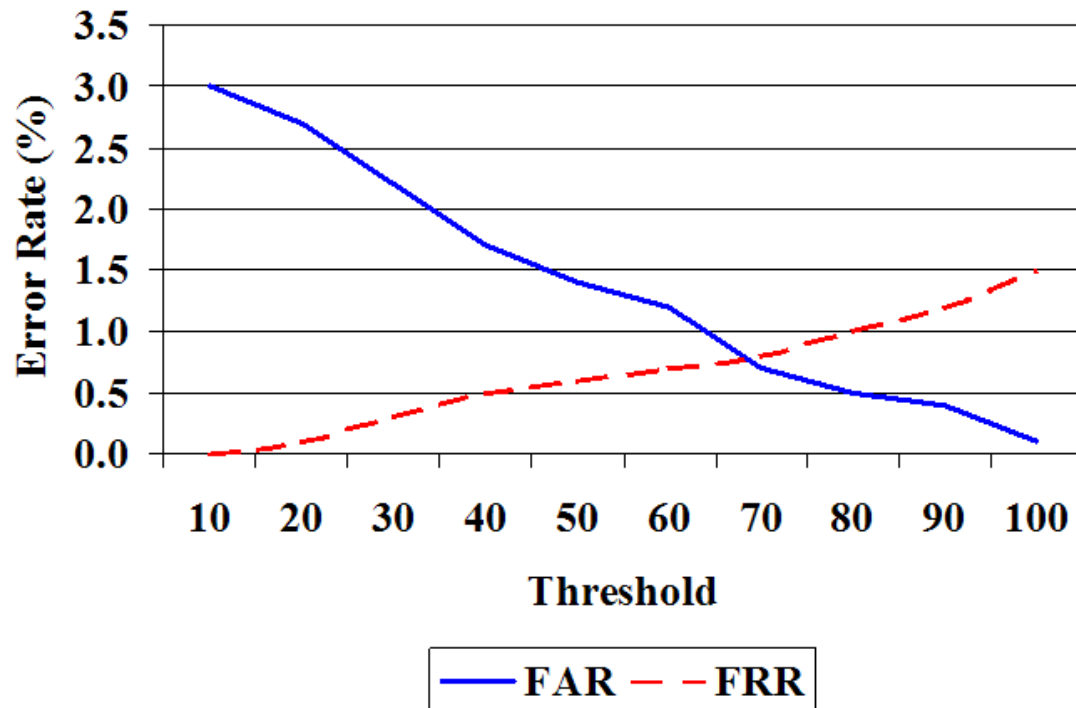


Biometrics market share (2015)

Sistem Biometric



Performanța Sistemelor Biometrice



- False Acceptance Rate (FAR) – Procentul de impostori acceptați în mod greșit de către sistem
- False Rejection Rate (FRR) – Procentul de utilizatori valizi rejectați în mod greșit de către sistem
- Threshold – Valoare ce trebuie setată pentru a controla rata erorilor

Evaluarea Metodelor de Autentificare

Cerințe Organizaționale

- Nivelul de securitate asigurat
- Interoperabilitate
- Robustețe / Scalabilitate
- Flexibilitate

Total Cost of Ownership

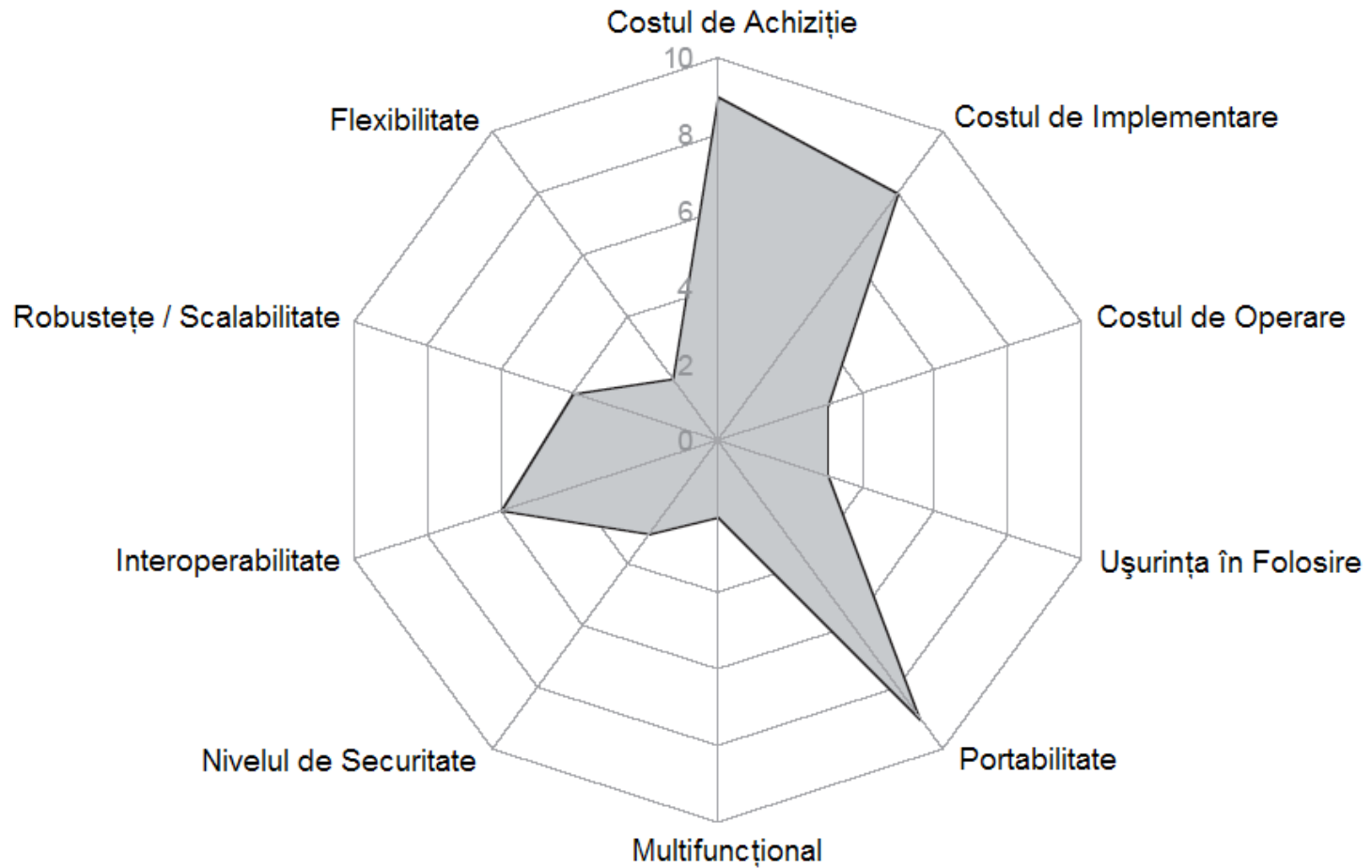
- Costul de achiziție
- Costul de implementare
- Costul de operare

Cerințe Utilizator

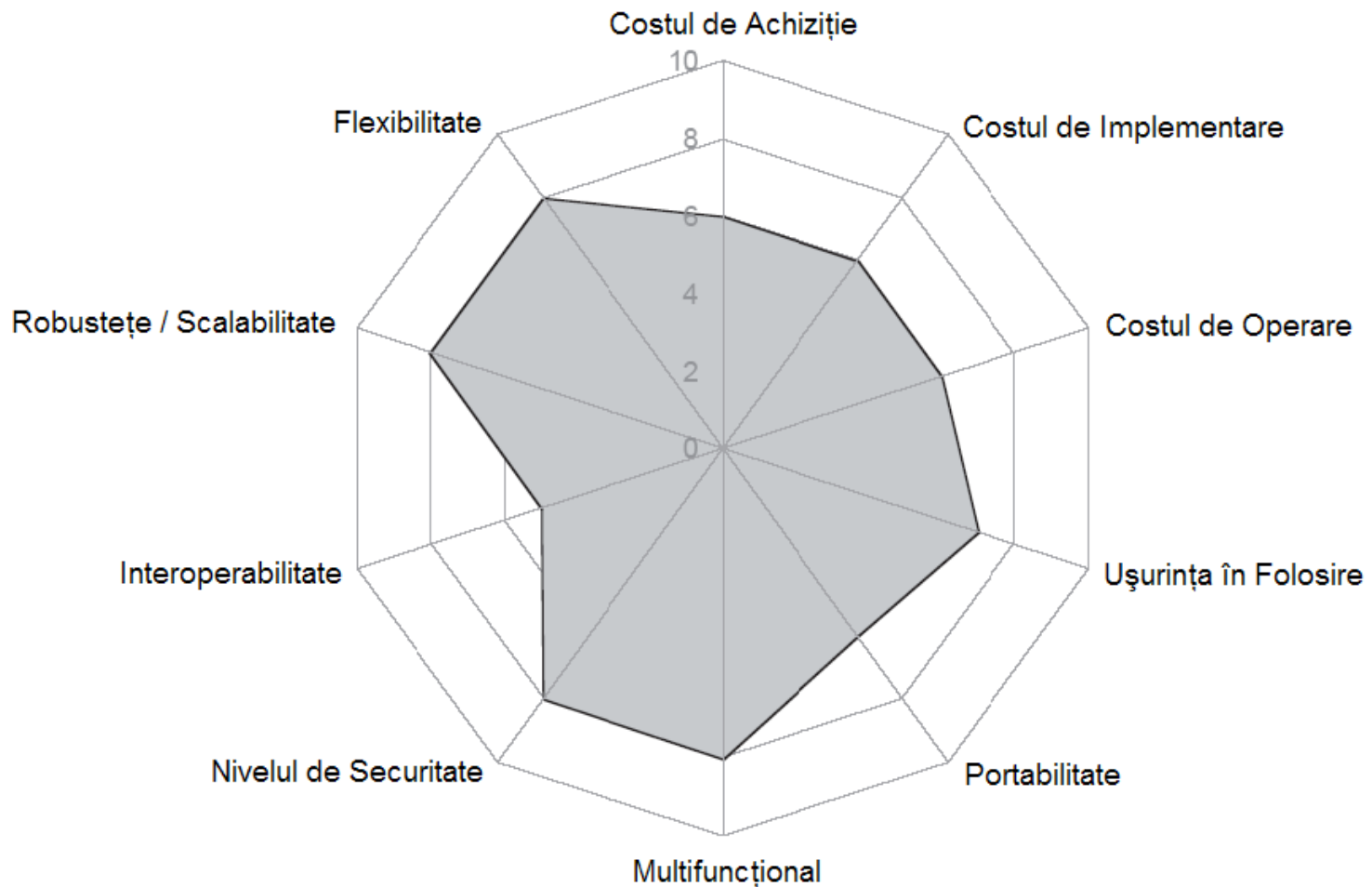
- Ușurința în folosire
- Portabilitate
- Multifuncțional

“Există vreo metodă care să satisfacă toate aceste cerințe?”

Parola/PIN



Certificat Digital + Smart Card





2. Protocoale de Securitate la Nivel Rețea



Rețele Private Virtuale

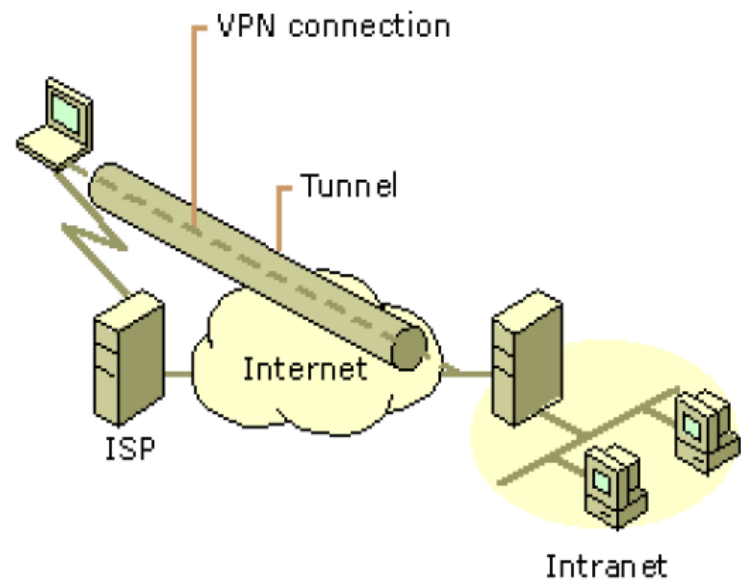
- Liniile de comunicație dedicate sunt în scumpe
- Internetul oferă conectivitate globală
 - calitatea legăturilor de comunicații
 - securitatea datelor
- Rețea Privată Virtuală (VPN – Virtual Private Network) – interconectează componentele unei rețele private prin intermediul unei rețele publice (Internet-ul, de exemplu)
 - Interconectare utilizatori remote
 - Interconectare sucursale
 - Interconectare cu parteneri de afaceri

Tehnologii de tunelare a datelor

- **Tunelarea datelor**
 - încapsularea datelor a.î. acestea să poată fi transmise în siguranță prin intermediul rețelei publice
- **Tehnologii de tunelare a datelor:**
 - Nivel 2: PPTP, L2TP
 - Nivel 3: IPSec
 - Nivel 4: SSL

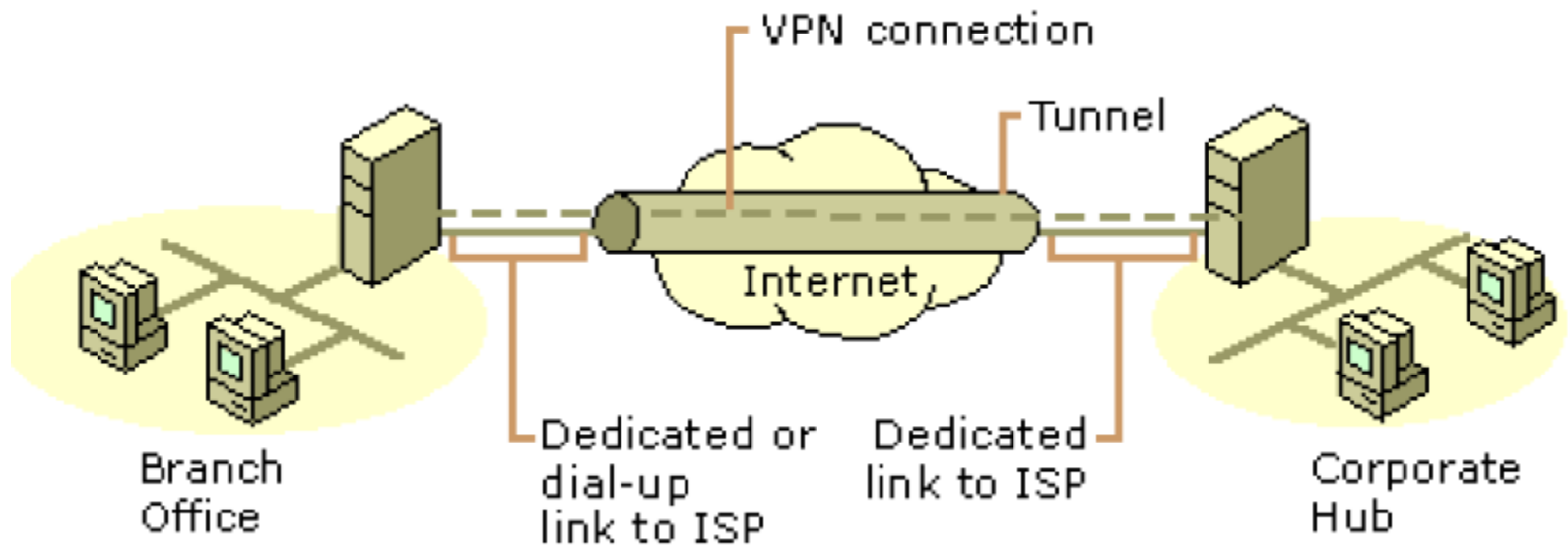
Remote Acces VPN

- Conectarea utilizatorilor de la distanță în LAN
- Utilizatorul se conectează mai întâi la Internet prin intermediul ISP-ului local
- Utilizatorul stabilește un tunel prin Internet cu gateway-ul de acces în rețeaua locală
- Costul VPN este dat de legătura locală la Internet



Site to Site VPN

- Interconectare sucursale, parteneri de afaceri
- Tunelul de stabilește între gateway-uri
- Costul VPN este același cu costul de acces la Internet



Avantajele VPN

- **Flexibilitate**
- **Ușurința administrării:**
 - dispăre efortul necesar instalării și întreținerii unor legături de comunicație dedicate
- **Dispare riscul învechirii morale a tehnologie**
 - costul schimbării echipamentelor este treaba ISP
- **Scalabilitate**
 - Pentru a conecta o nouă sucursală la LAN nu trebuie decât să o conectez la Internet și apoi să configurez tunelul VPN
- **Conectivitate globală**

IPSec

- **Completează IPv4 cu facilități de securitate**
- **Protocol de Nivel 3+**
- **Pune la dispoziția protocoalelor de pe nivelul superior (TCP, UDP) servicii de comunicație securizate**
- **Pentru a suporta IPSec, stiva TCP/IP de pe clienți sau gateway-uri trebuie modificată**

Arhitectura IPSec

- **Descris în cadrul mai multor RFC**
 - **RFC 4301: An overview of the IPSec security architecture**
 - **RFC 4302: Specification of AH**
 - **RFC 4303: Specification of ESP**
 - **RFC 4305: Specification of algorithms for AH and ESP**
 - **RFC 4306: Specification of IKEv2**
 - ...
- **Destul de complex, foarte multe opțiuni**
- **Probleme de interoperabilitate între diferite implementări**

AH și ESP

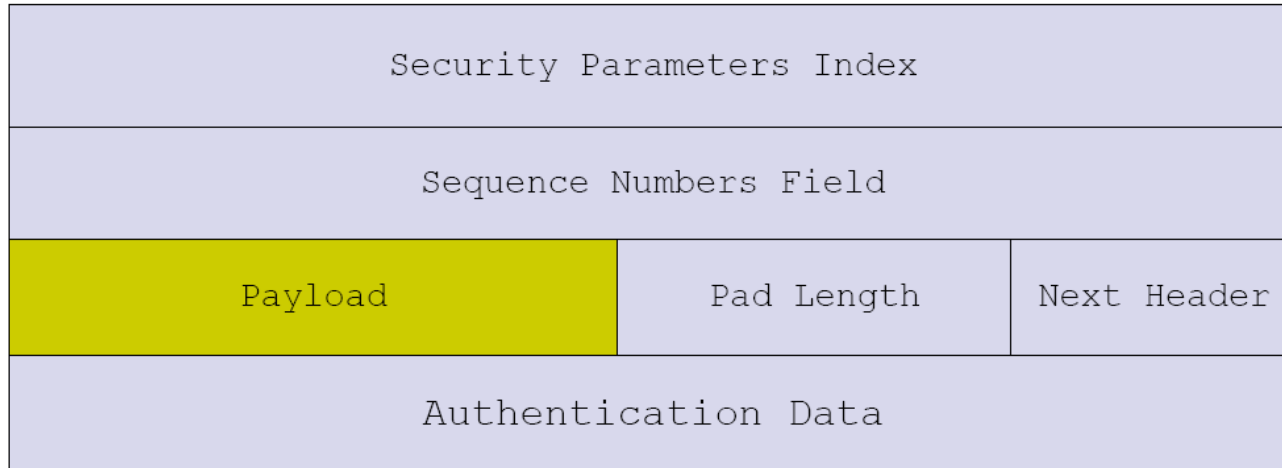
- **Authentication Header Protocol (AH)**
 - Integritatea pachetelor
 - Autentificarea originii datelor
- **Encapsulating Security Payload Protocol (ESP)**
 - Confidențialitatea datelor
 - Autentificarea originii datelor
- **Pot fi folosite independent sau combinat**
- **Moduri de operare**
 - Transport
 - Tunel

Authentication Header Protocol

Next Header	Payload Length	Reserved
Security Parameters Index		
Sequence Numbers Field		
Integrity Check Value		

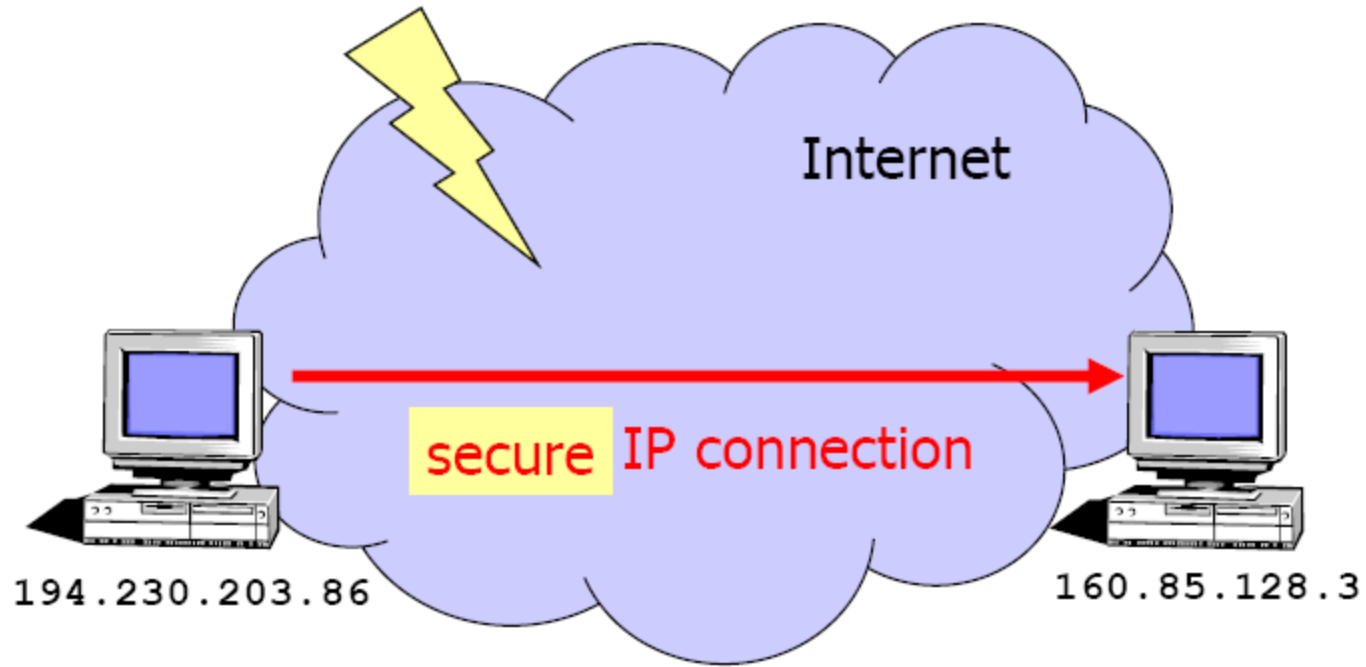
- Numărul de protocol pentru AH este 51
- Numărul de secvență evită atacurile prin reluare
- Câmpul *Integrity Check Value* este calculat pentru toate câmpurile din pachetul IP cu excepția celor ce pot suferi modificări (TOS, TTL, CRC, etc)

Encapsulating Security Payload Protocol



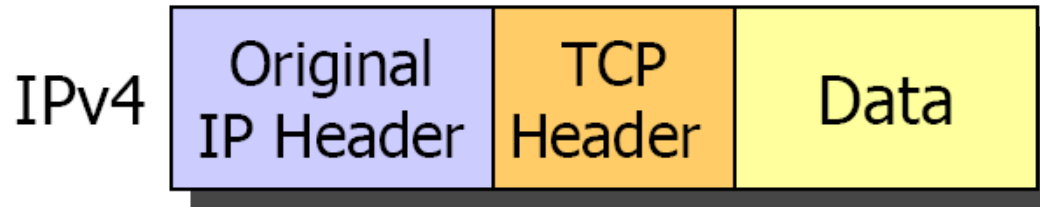
- Numărul de protocol pentru ESP este 50
- *Authentication Data* este calculat numai pentru câmpurile din ESP

IPSec – Modul Transport



IPSec – Modul Transport (AH)

Before applying AH



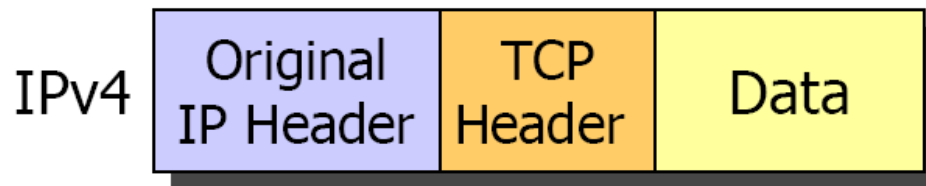
After applying AH



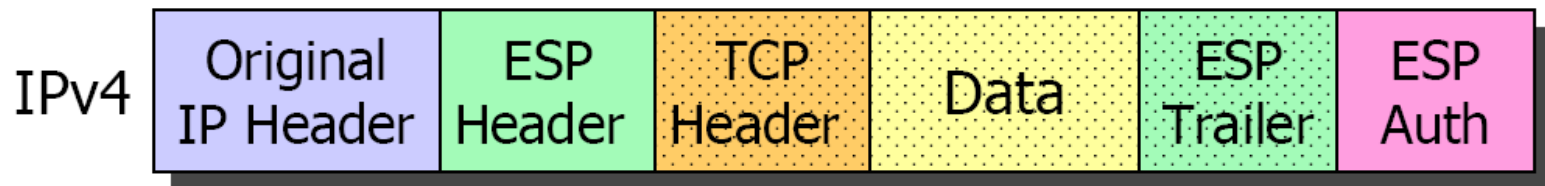
← authenticated →
except for mutable fields

IPSec – Modul Transport (ESP)

Before applying ESP

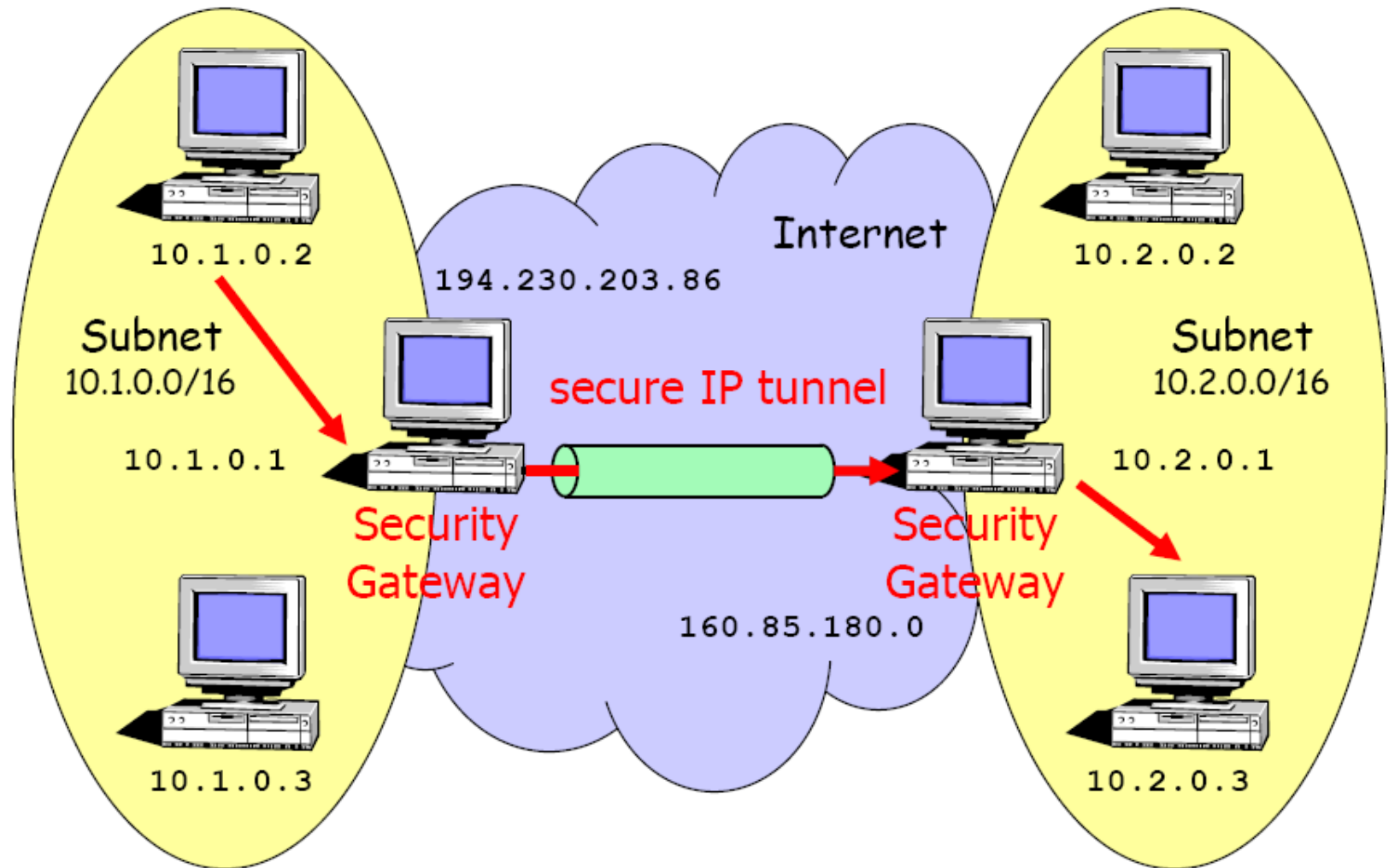


After applying ESP



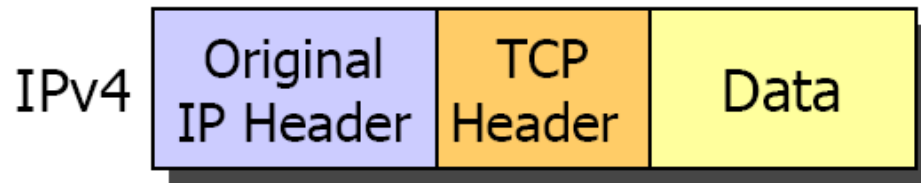
← encrypted →
← authenticated →

IPSec – Modul Tunnel

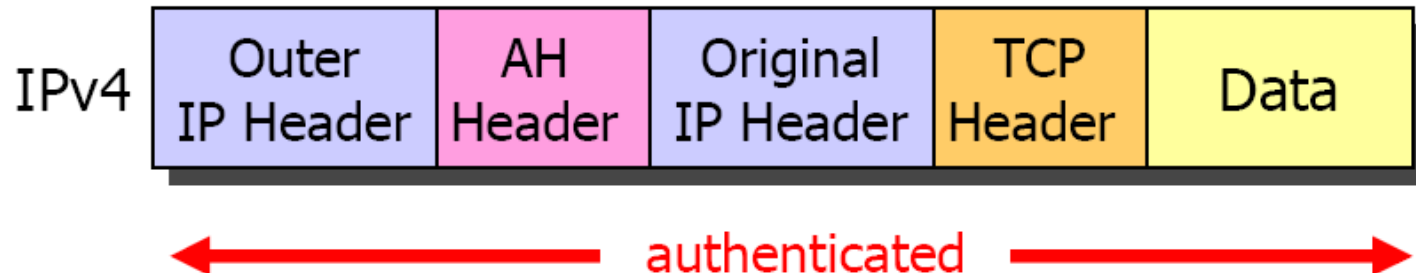


IPSec – Modul Tunel (AH)

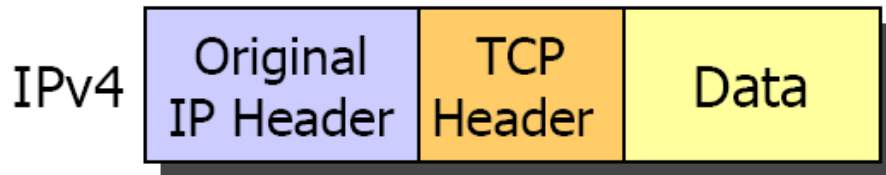
Before applying AH



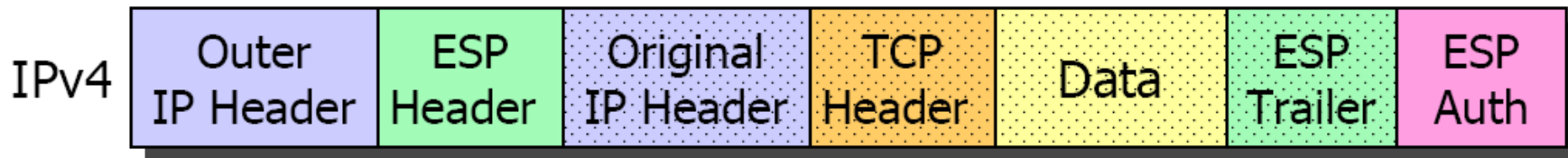
After applying AH



IPSec – Modul Tunel (ESP)



After applying ESP



← encrypted →
← authenticated →

Security Association (SA)

- Un SA este un “contract” stabilit între cele două capete ale tunelului IPSec
 - parametrii criptografici (algoritmi, chei, etc)
 - timp de viață
- SA sunt stocate într-o bază de date. Fiecare SA are asociat un SPI (Security Parameters Index) pentru a putea fi regăsit în baza de date

Internet Key Exchange

- **Managementul asocierilor de securitate (SA)**
 - manual
 - automat
- **ISAKMP (Internet Security Association and Key Management)**
 - framework pentru managementul cheilor și asocierilor de securitate
- **IKE (Internet Key Exchange)**
 - stabilirea parametrilor criptografici
 - algoritmul de criptare, funcția hash, metoda de autentificare, etc
 - autentificarea mutuală între entități
 - pre-shared keys sau certificate digitale
 - stabilirea cheii de sesiune
 - Diffie Hellman (DH)
 - folosește portul UDP 500 pentru comunicație
 - RFC 4306 (IKE v2)

Moduri de lucru

■ Faza 1

- negocierea unui SA inițial (ISAKMP SA)
- Modul principal
 - 6 mesaje
- Modul agresiv
 - 3 mesaje
 - nu asigură protecția identității

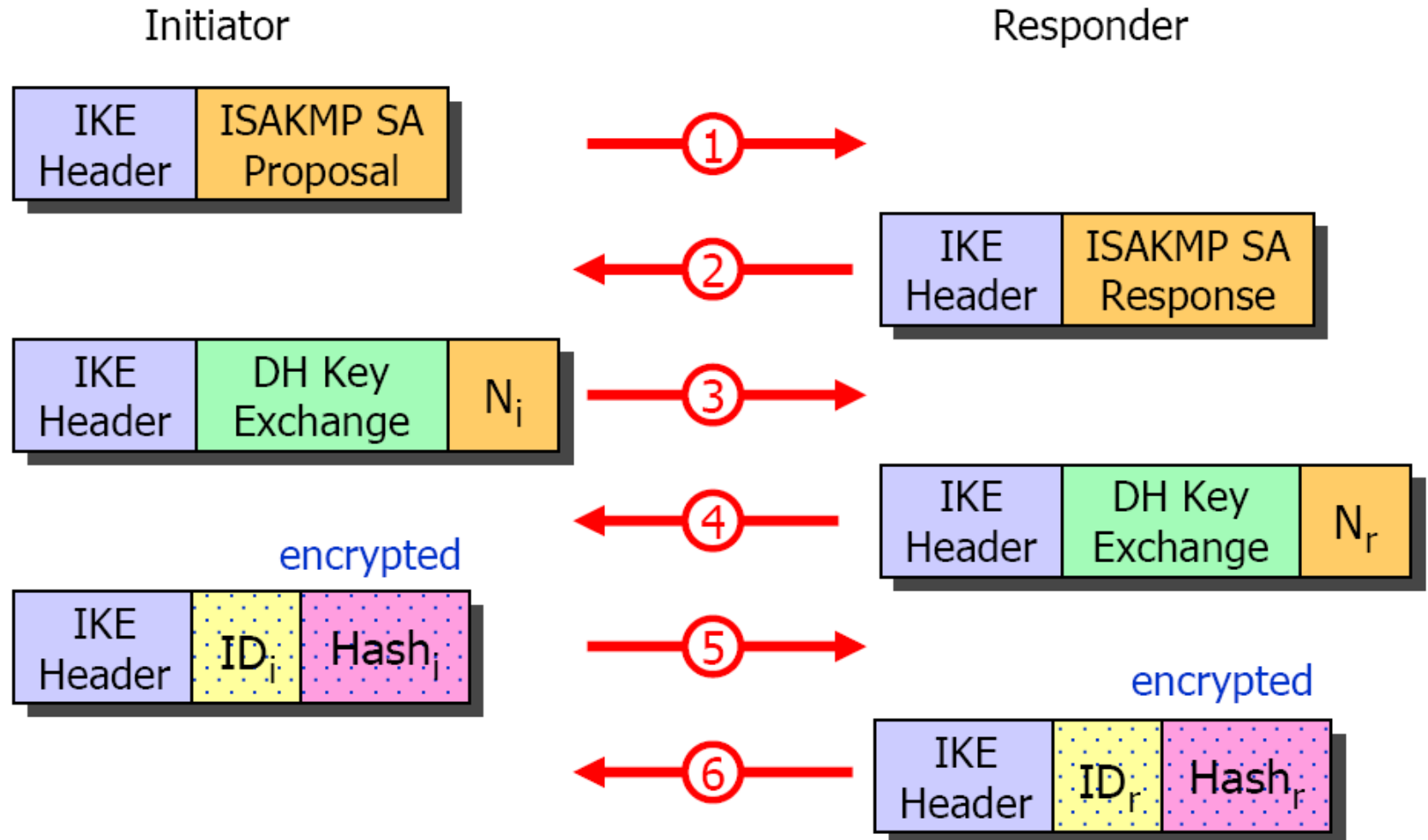
■ Faza 2

- negocierea unui SA general (IPSec SA)
- reîmprospătarea cheilor de sesiune
- Modul rapid

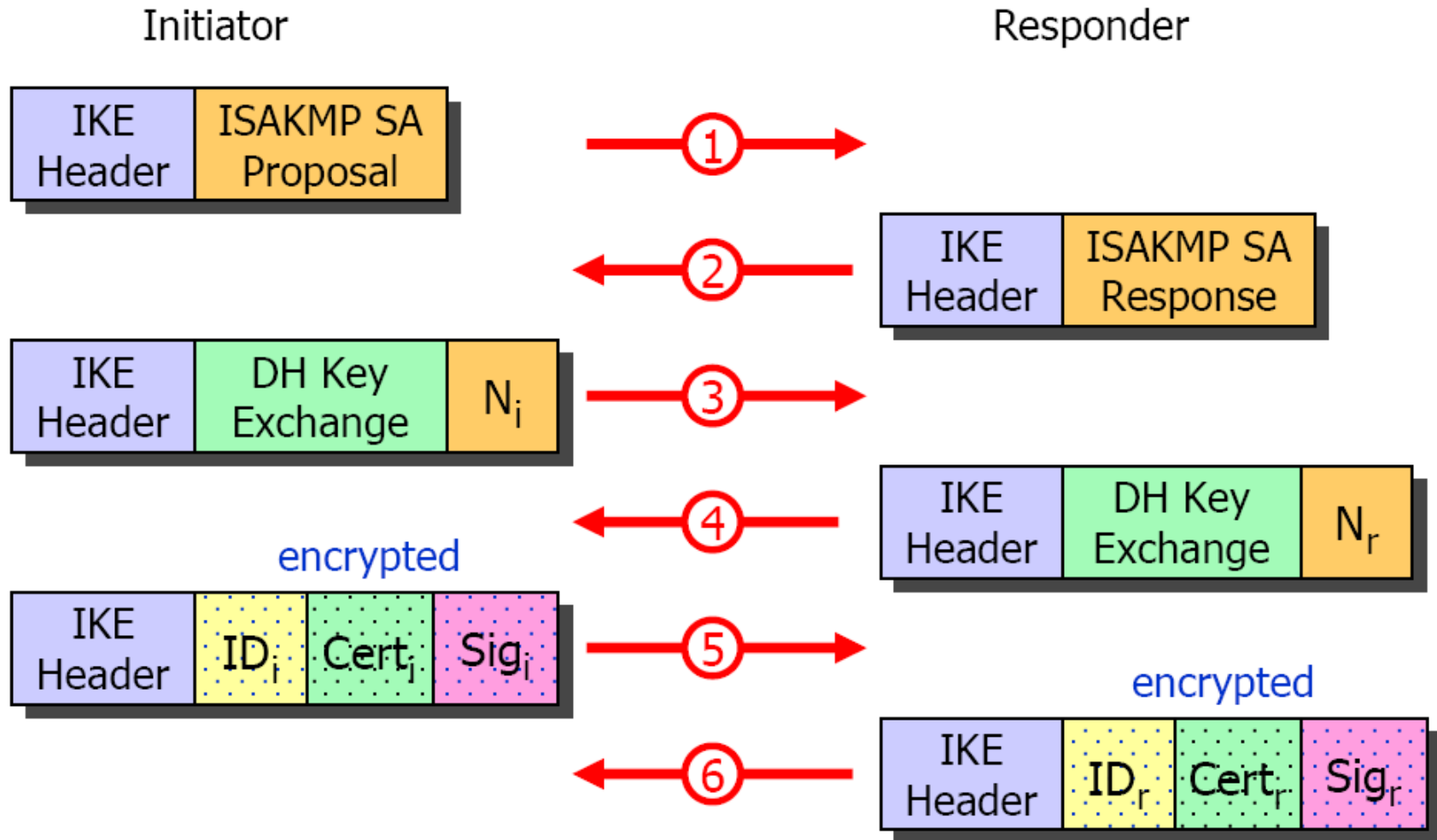
Moduri de lucru (cont.)

- Se folosește modul principal / agresiv pentru a stabili un SA inițial (ISAKMP SA)
- Se folosește modul rapid pentru a negocia un SA general (IPSec SA)
- Se folosește IPSec SA pentru transmiterea datelor până când acesta expiră și trebuie negociat un nou IPSec SA
- Se folosește modul rapid pentru reînnoirea IPSec SA

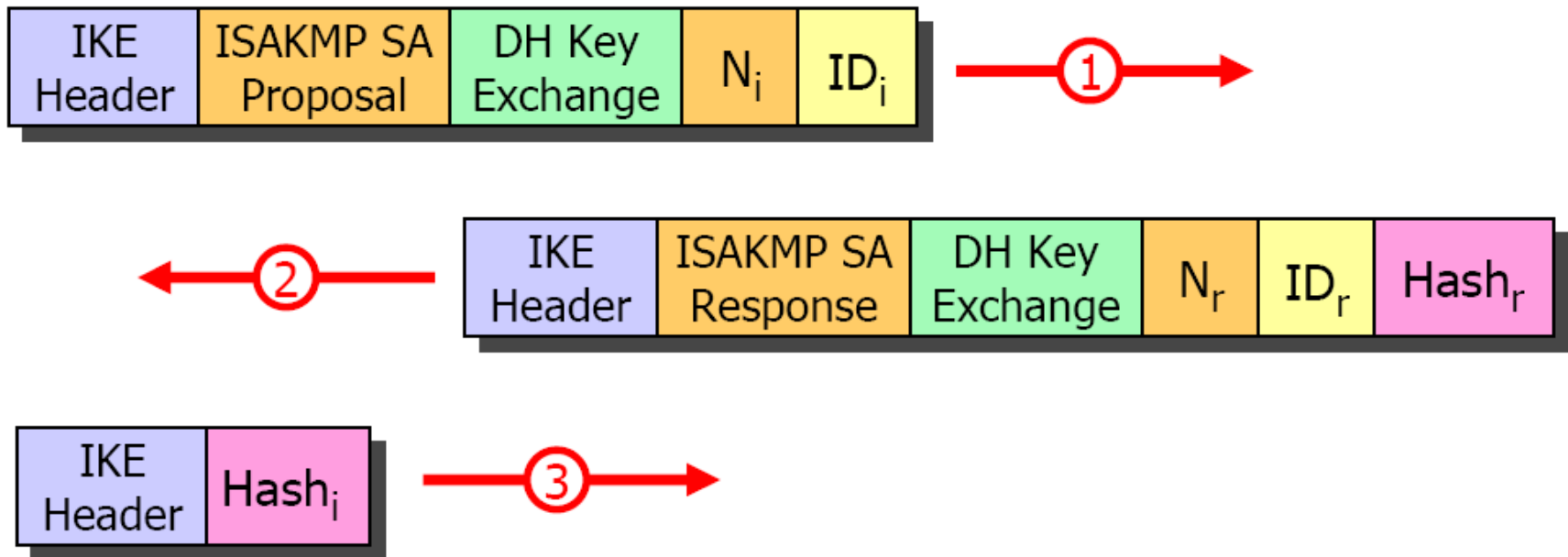
IKE - Modul Principal



IKE - Modul Principal (cont.)



IKE – Modul Agresiv

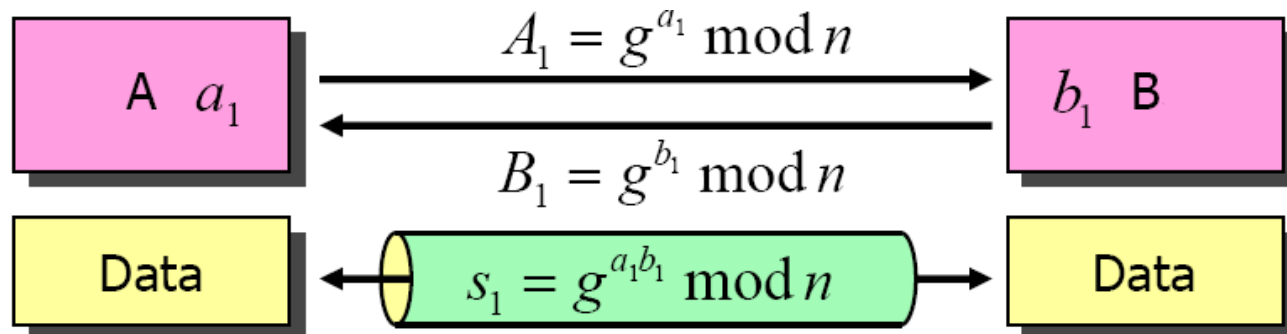


IKE – Modul Rapid

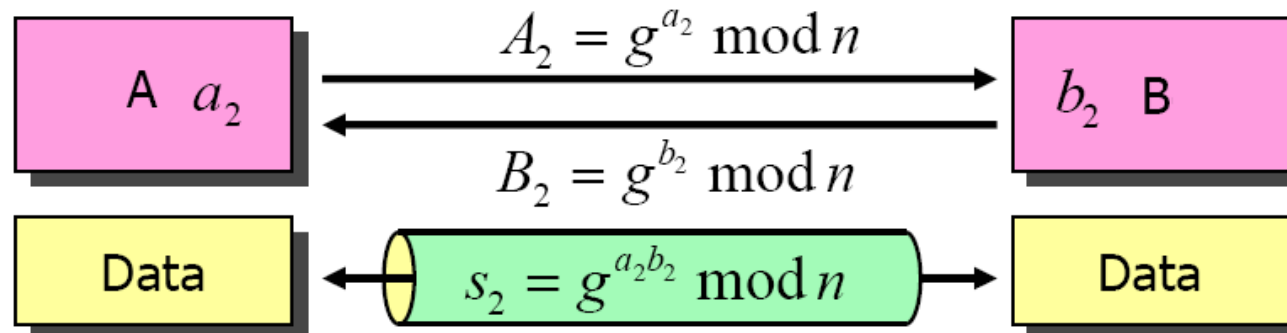
- Schimb de mesaje criptate folosind cheia de sesiune stabilită în faza 1
- Negocierea parametrilor pentru IPSec SA
- 3 mesaje
- IPSec SA este bidirecțional (unul pentru conexiunea de intrare și unul pentru conexiunea de ieșire)
- Schimbarea periodică a cheilor de sesiune
 - Perfect Forward Secrecy

Perfect Forward Secrecy

- Session 1: October 25 2024 10:00



- Session 2: October 25 2024 11:00



- Compromiterea lui s_1 nu duce la compromiterea lui s_2 !

Implementarea IPSec VPN

- **Algoritmi criptografici recomandați**
 - criptarea datelor: 3DES, AES
 - integritatea datelor: SHA-2
- **Fragmentarea pachetelor**
 - antetele AH și ESP cresc dimensiunea pachetelor
 - scăderea performanței rețelei
- **Translația de adresă (NAT)**
 - translația de adresă modifică pachetele IP!
 - folosire NAT înainte de IPSec
 - IPSec NAT Traversal (NAT-T)
 - încapsularea pachetelor IPSec în datagrame UDP
- **Configurare firewall**
 - AH (IP Protocol Number 51), ESP (IP Protocol Number 50)
 - IKE (UDP Port 500)
 - IPSec NAT-T (UDP Port 4500)
- **L2TP/IPSec**
 - asignare adrese IP pentru clienții VPN prin DHCP
- **Suport pentru mecanisme extinse de autentificare**
 - Extended Authentication (XAUTH)
 - RADIUS, TACACS+, RSA SecurID

Soluții IPSec VPN

- Cisco
- Juniper
- CheckPoint VPN-1
- Microsoft
- Linux (2.4 / 2.6 Kernel with KLIPS / KAME)
 - strongSwan / Openswan
- FreeBSD / NetBSD / OpenBSD
 - KAME, Racoon IKE daemon



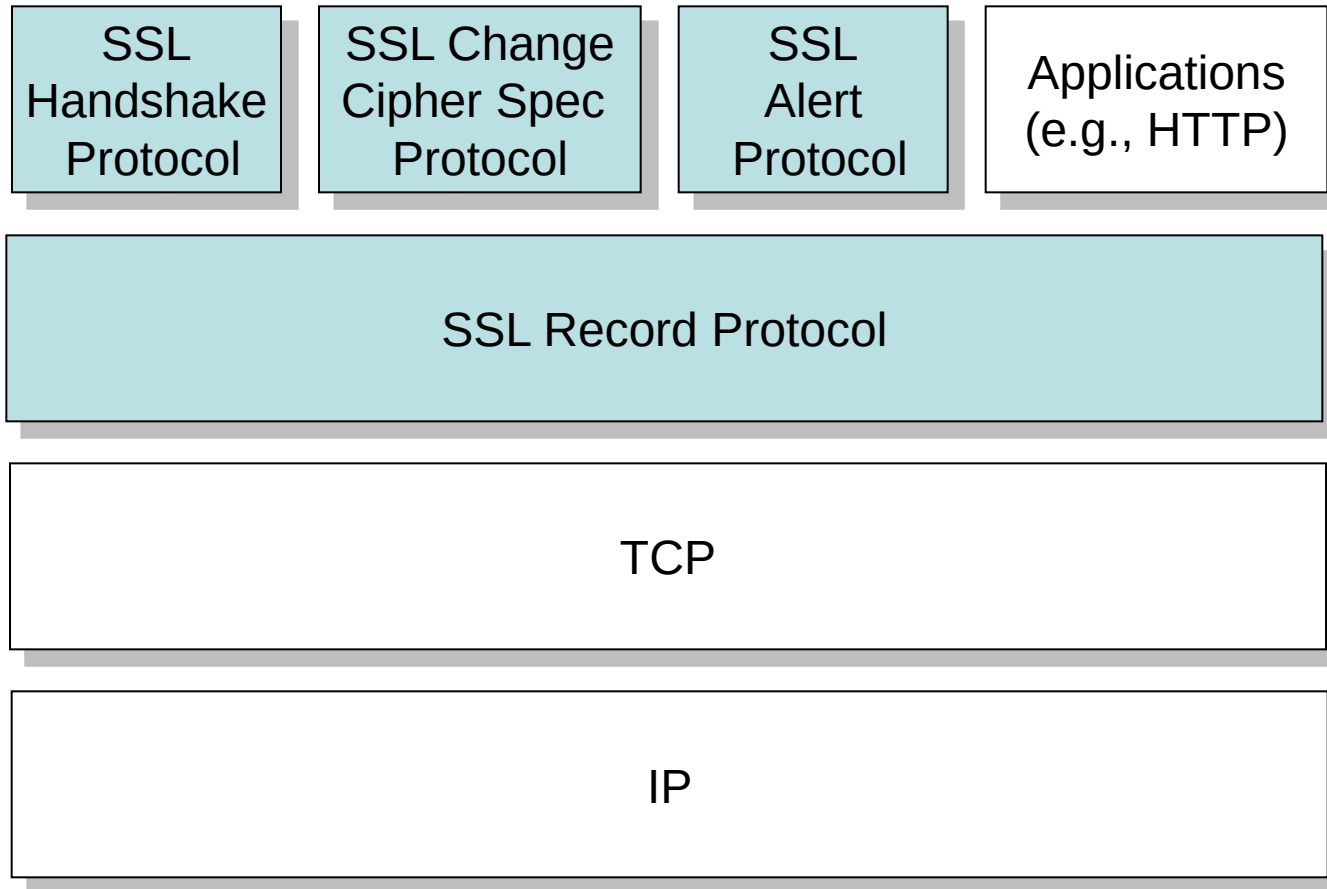
3. Protocole de Securitate la Nivel Transport



Protocolul SSL

- **Propus de firma Netscape**
 - <http://wp.netscape.com/eng/ssl3/ssl-toc.html>
- **Protocol de Nivel 4+**
 - se bazează pe mecanismele de comunicație existente în TCP
 - pune la dispoziția aplicațiilor socket-uri de comunicație securizate
 - aplicațiile trebuie modificate să suporte acest lucru – “SSLizare”
 - stiva TCP/IP de pe client/server nu trebuie modificată!
- **SSL v3.0 - Internet Draft (1996)**
- **TLS v1.0 - RFC 2246**
- **TLS v1.1 - RFC 4346**
- **TLS v1.2 - RFC 5246**
- **TLS v1.3 - RFC 8446**

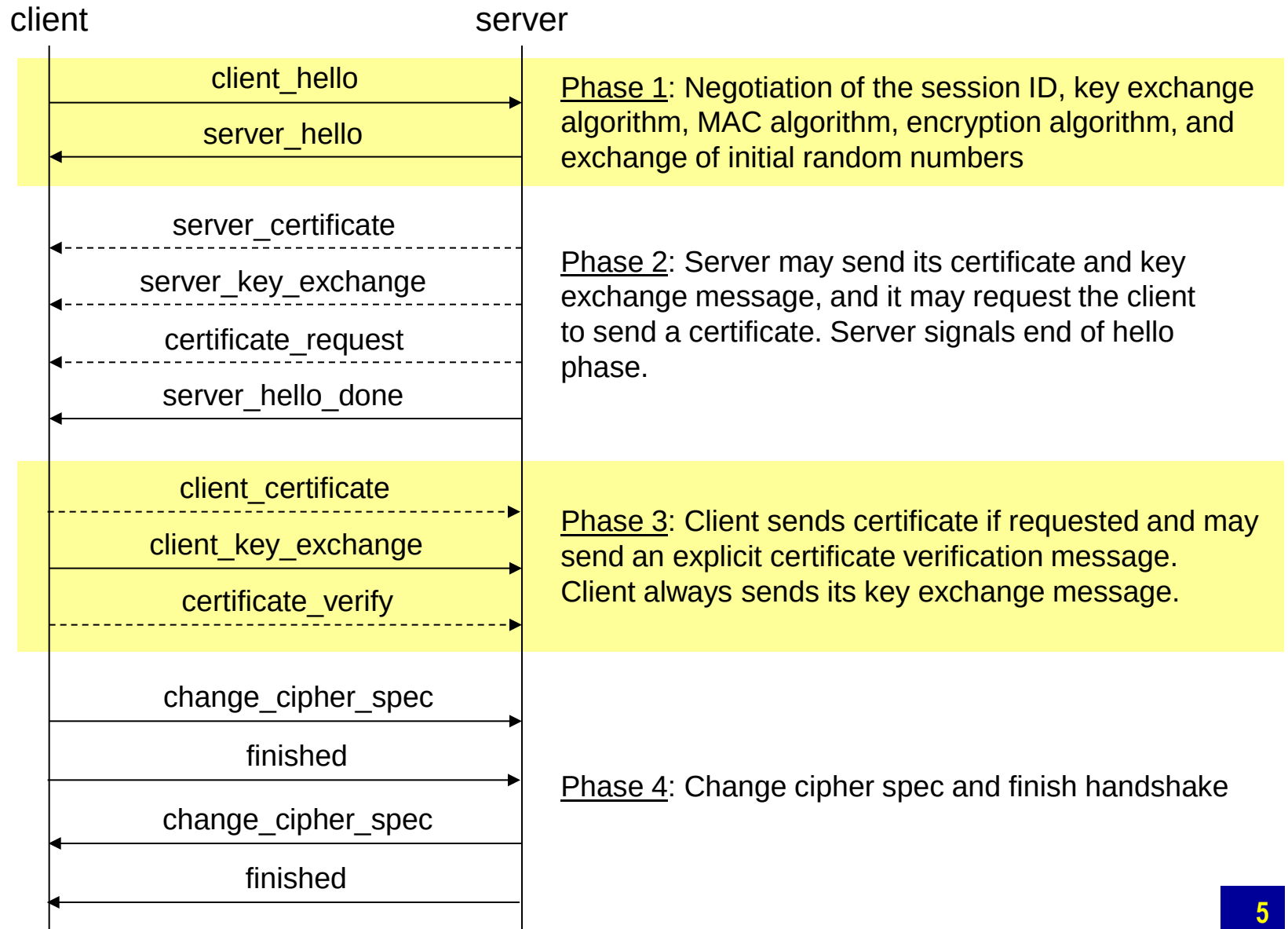
Protocolul SSL (cont.)



Protocolul SSL (cont.)

- **SSL Handshake Protocol (Protocolul de Negociere a Conexiunii)**
 - negocierea algoritmilor și parametrilor criptografici
 - schimbul de chei
 - autentificare server și opțional client
- **SSL Record Protocol (Protocolul de Transfer al Datelor)**
 - fragmentarea datelor
 - compresia datelor
 - autenticitatea și integritatea datelor (folosind MAC)
 - criptarea datelor (folosind algoritmi simetrici)
- **SSL Change Cipher Spec Protocol**
 - un singur mesaj ce indică sfârșitul fazei de handshake
- **SSL Alert Protocol**
 - mesaje de eroare

SSL Handshake Protocol



SSL Handshake Protocol (cont.)

- **Autentificarea entităților**
 - certificate digitale
 - obligatoriu pentru server, opțional pentru client
- **Mecanisme pentru schimbul de chei**
 - RSA based
 - cheia de secretă este criptată cu cheia publică a serverului
 - Fixed Diffie-Hellman
 - certificat digital în care sunt stabiliți parametrii DH
 - Ephemeral Diffie-Hellman
 - parametrii DH sunt generați aleator și semnați folosind RSA / DSA
 - Anonymous Diffie-Hellman
 - parametrii DH sunt generați aleator și transmiși fără autentificare
 - Fortezza
 - schemă proprietară

SSL Handshake Protocol (cont.)

1. client_hello

- **client_version**
 - versiunea de protocol suportă de client
- **client_random**
 - timpul curent (4 octeți) + date aleatoare (28 octeți)
- **session_id**
- **cipher_suites** (lista algoritmilor criptografici suportați de client)
 - exemplu: SSL_RSA_with_3DES_EDE_CBC_SHA, ...
- **compression_methods** (lista algoritmilor de compresie suportați de client)

2. server_hello

- **server_version**
 - min (versiunea suportă de client, versiunea suportă de server)
- **server_random**
 - timpul curent (4 octeți) + date aleatoare (28 octeți)
- **session_id**
- **cipher_suite** (algoritmul criptografic selectat de server din lista propusă de client)
- **compression_method** (algoritmul de compresie selectat de server din lista propusă de client)

SSL Handshake Protocol (cont.)

3. server_certificate

- certificat X.509 (RSA / DSA / DH)

4. server_key_exchange

- cheia publică RSA / parametrii DH

5. certificate_request

- transmis numai dacă se cere autentificarea clientului
- specifică tipul de certificat cerut

6. server_hello_done

- indică faptul că serverul a încheiat schimbul de chei

SSL Handshake Protocol (cont.)

7. client_certificate

- transmis numai dacă serverul cere clientului să se autentifice
- certificat X.509 (RSA / DSA / DH)

8. client_key_exchange

- cheia secretă criptată cu cheia publică a serverului / parametrii DH

9. certificate_verify

- transmis numai dacă serverul cere clientului să se autentifice
- mesaj semnat digital pentru autentificarea clientului

SSL Handshake Protocol (cont.)

10. client change_cipher_spec

- clientul anunță serverul că a terminat de încărcat noile configurații criptografice

11. client finished

12. server change_cipher_spec

- serverul anunță clientul că a terminat de încărcat noile configurații criptografice

13. server finished

Generarea cheilor criptografice

```
master_secret = MD5(pre_master_secret + SHA('A' + pre_master_secret + ClientHello.random +  
    ServerHello.random)) + MD5(pre_master_secret + SHA('BB' + pre_master_secret +  
    ClientHello.random + ServerHello.random)) + MD5(pre_master_secret + SHA('CCC' +  
    pre_master_secret + ClientHello.random + ServerHello.random));
```

```
key_block = MD5(master_secret + SHA('A' + master_secret + ServerHello.random +  
    ClientHello.random)) + MD5(master_secret + SHA('BB' + master_secret + ServerHello.random +  
    ClientHello.random)) + MD5(master_secret + SHA('CCC' + master_secret + ServerHello.random  
    + ClientHello.random)) + [...];
```

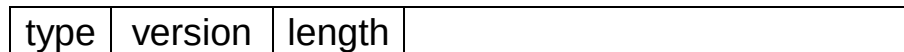
```
client_write_MAC_secret[CipherSpec.hash_size]  
server_write_MAC_secret[CipherSpec.hash_size]  
client_write_key[CipherSpec.key_material]  
server_write_key[CipherSpec.key_material]  
client_write_IV[CipherSpec.IV_size]  
server_write_IV[CipherSpec.IV_size]
```

SSL Record Protocol

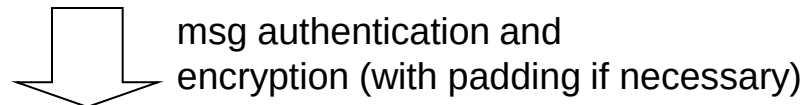
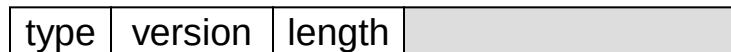
application data



SSLPlaintext



SSLCompressed



SSLCiphertext



Message Authentication Code

- **sumă de control securizată**
 - poate fi calculată numai cu ajutorul unei chei secrete

- **IETF RFC 2104**

**HMAC = hash(MAC_write_secret + pad_2 +
hash (MAC_write_secret + pad_1 +
seq_num + length + content));**

- **hash: MD5, SHA-1**
- **pad_1 = 0x36 (repetată de 48 de ori în cazul MD5 și de 40 de ori în cazul SHA-1)**
- **pad_2 = 0x5C (repetată de 48 de ori în cazul MD5 și de 40 de ori în cazul SHA-1)**

Criptarea datelor

- **Cifruri block**
 - RC2_40
 - DES_40
 - DES_56
 - 3DES_168
 - IDEA_128
 - Fortezza_80
- **Cifruri şir**
 - RC4_40
 - RC4_128

Protocolul TLS

- **Rezultatul standardizării SSL de către IETF**
 - IETF RFC 2246
- **Diferențe față de SSL**
 - Numărul versiunii
 - Suport pentru noi algoritmi criptografici (3DES, AES)
 - Modul de calcul al MAC (XOR în loc de ||)
 - Modul de generare a cheilor criptografice (PRF)
 - Mesaje de alertare adiționale
 - Formatul mesajelor (certificate_verify, finished)
 - Modul de completare a datelor (padding)
- **Suport pentru algoritmi criptografici de ultimă generație**
 - AES, Camellia, GOST
 - SHA-2

Implementarea SSL/TLS

- **Certificate digitale**
 - Server Authentication
 - Client Authentication
- **Securizarea tranzacțiilor Web (https)**
- **“SSLizare” aplicații: librării criptografice**
 - BSAFE (RSA Security)
 - OpenSSL (www.openssl.org)

Achiziționare certificat de server

- **Domain validation**
 - se verifică doar existența domeniului
 - emis foarte repede
- **Organization validation**
 - se verifică existența organizației și a domeniului
 - emis în câteva zile
- **Extended validation**
 - verificări amănunțite cu privire la organizație și domeniu
 - emis în câteva săptămâni
- **Certificate transparency**
 - Registru distribuit (distributedledger) pentru monitorizarea și auditarea certificatelor emise de o autoritate de certificare
 - RFC 9162

Porturi SSL standard

Serviciu	Port	Descriere
https	443/tcp	http protocol over TLS/SSL
smtps	465/tcp	smtp protocol over TLS/SSL
nntp	563/tcp	nntp protocol over TLS/SSL
ssh	614/tcp	SSLshell
ldaps	636/tcp	ldap protocol over TLS/SSL
ftps-data	989/tcp	ftp protocol, data, over TLS/SSL
ftps	990/tcp	ftp, control, over TLS/SSL
telnet	992/tcp	telnet protocol over TLS/SSL
imaps	993/tcp	imap4 protocol over TLS/SSL
ircs	994/tcp	irc protocol over TLS/SSL
pop3s	995/tcp	pop3 protocol over TLS/SSL

Atacuri împotriva SSL/TLS

- Renegotiation attack
 - RC4 attacks
 - BEAST attack
 - CRIME attack
 - Heartbleed
 - ChangeCipherSpec injection attack
 - POODLE attack against TLS
 - Protocol downgrade
- Din motive de securitate, se recomandă să se dezactiveze suportul pentru SSL și să se folosească numai TLS



4. Protocoale de Securitate la Nivel Aplicație



Securitatea la nivel aplicație

- **Pretty Good Privacy (PGP)**
- **Secure Multipurpose Internet Mail Extensions (S/MIME)**
- **Secure Shell (SSH)**

...

Pretty Good Privacy

- **Phil Zimmerman, 1991**
- **Aplicație pentru protecția mesageriei electronice și a fișierelor stocate local**
- **Bazat pe algoritmi criptografici moderni**
- **Cod sursă disponibil free**
- **Disponibil pentru diferite tipuri de platforme (Windows, Unix, Mac OS, etc.)**
- **Standard Internet**
 - **OpenPGP Message Format (IETF RFC 4480)**
 - **MIME Security with OpenPGP (IETF RFC 3156)**

Servicii oferite

1. Autentificare
2. Confidențialitate
3. Compresie date
4. Compatibilitate e-mail

Notatii

Ks – cheie de sesiune

KRa – cheia privată a utilizatorului A

KUa – cheia publică a utilizatorului A

EP – proces de criptare cu chei publice

DP – proces de decriptare cu chei publice

EC - proces de criptare cu chei simetrice

DC - proces de decriptare cu chei simetrice

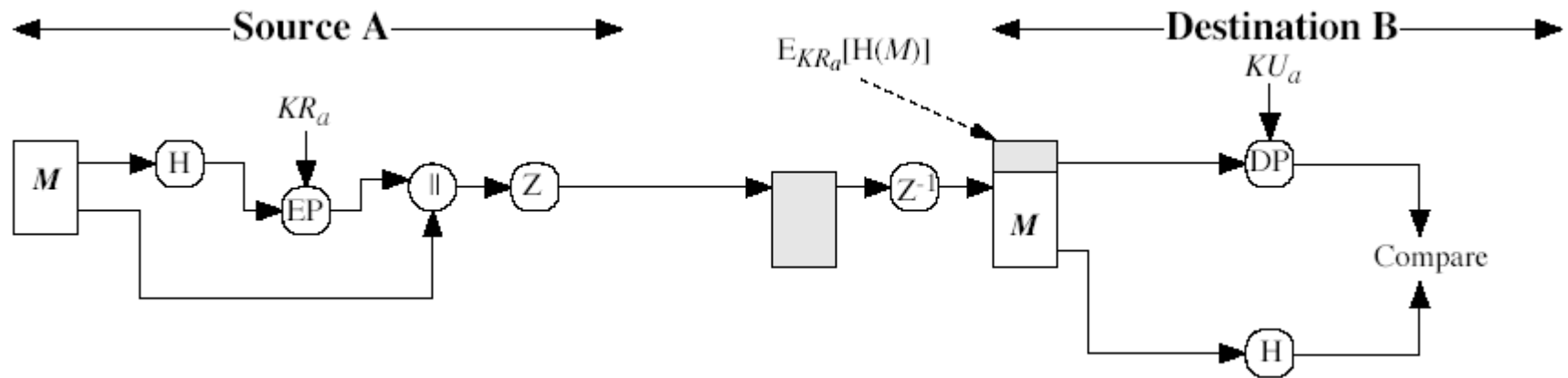
H – funcție hash

|| - concatenare

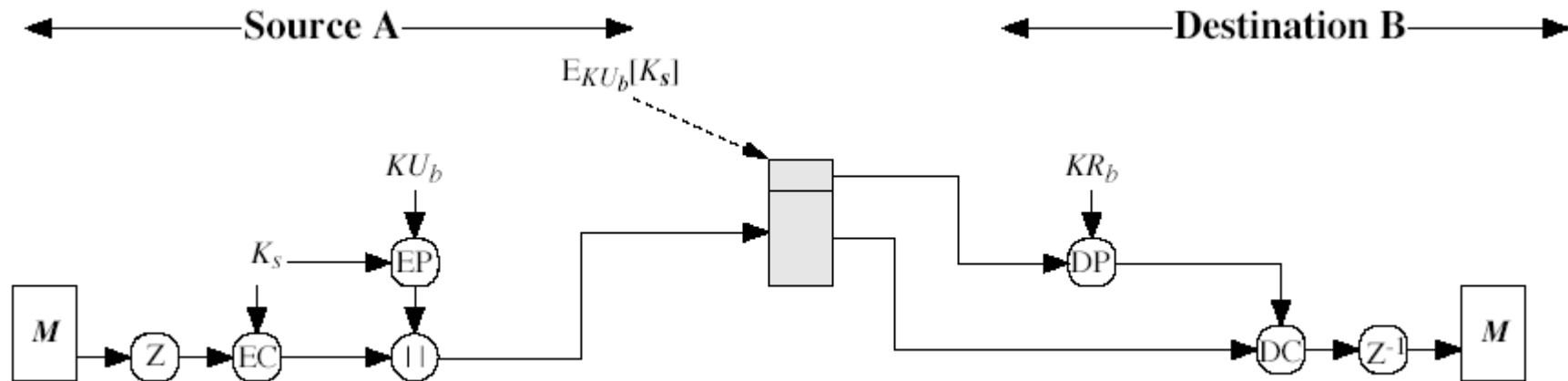
Z – compresie

R64 – conversie Radix 64

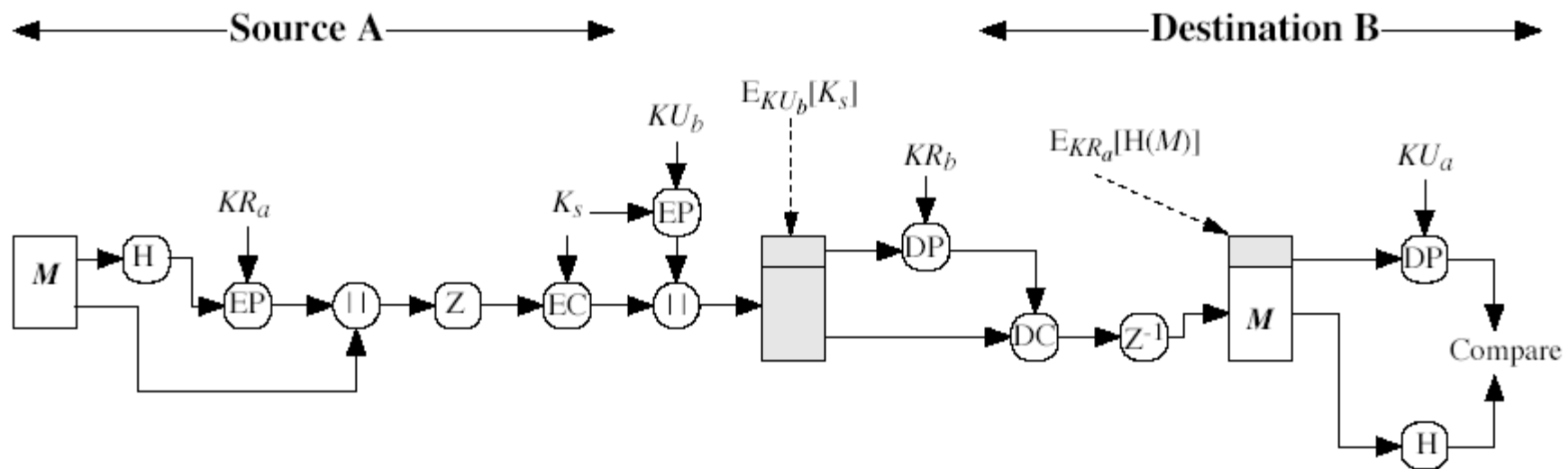
Autenticare



Confidențialitate



Autentificare și confidențialitate



Compresie date

- **Opțional, PGP poate comprima datele pentru a reduce durata procesărilor și încărcarea rețelei**
- **Compresia datelor se aplică înainte de criptare**
 - procesul de criptanaliza se complică
- **Algoritmul de compresie: ZIP / UNZIP**

Compatibilitate e-mail

- Mesajele semnate și criptate sunt în format binar (pot conține orice octet nu numai octeți tipăribili)
- Sistemele de mesagerie electronică suportă numai mesaje text
- Conversie Radix 64:
 - 3 blocuri de 8-biți → 4 blocuri de 6-biți
 - crește dimensiunea mesajelor cu 4/3 (x1,33)

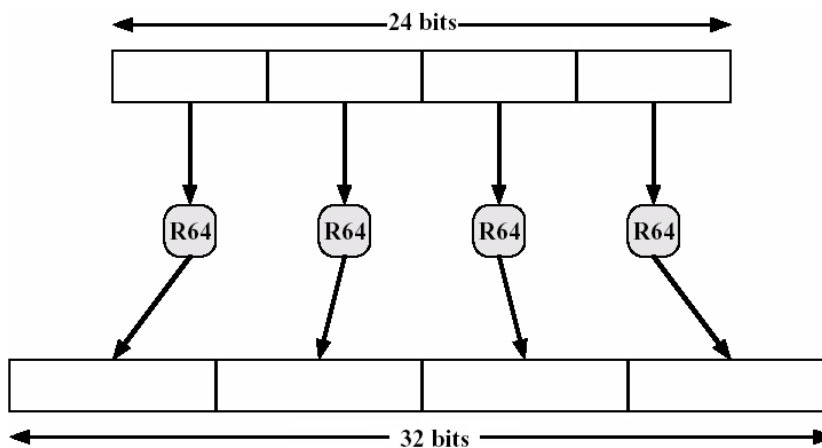


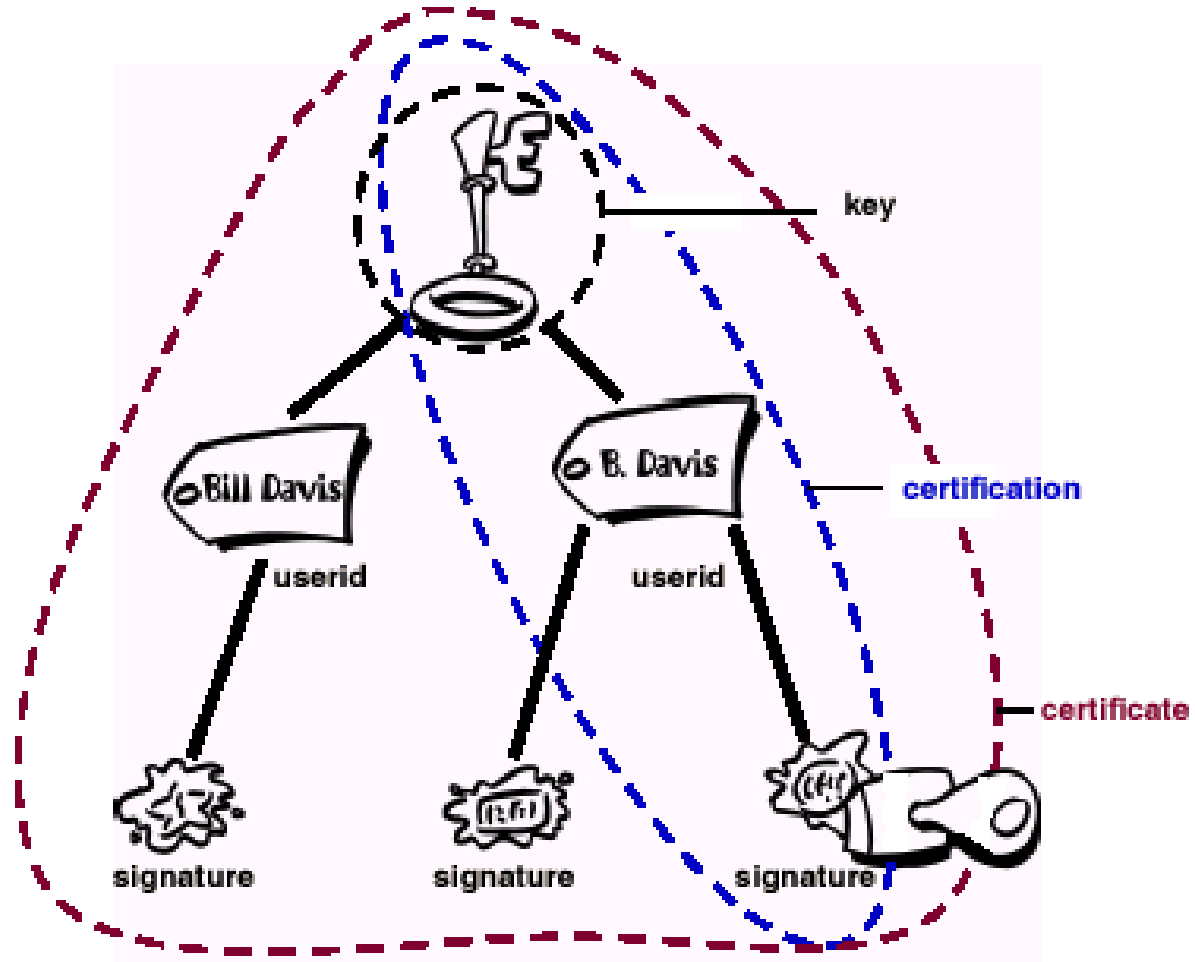
Tabela Radix-64

6 bit value	Character encoding	6 bit value	Character encoding	6 bit value	Character encoding	6 bit value	Character encoding
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/
						(pad)	=

Gestiunea cheilor

- **Modelul plasa de încredere (Web of Trust)**
 - recomandări de la persoane de încredere
 - Self-Managing Security Architecture
- **Inele de chei**
 - Public Key Ring
 - Private Key Ring
- **Distribuție**
 - floppy disk
 - e-mail (amprente de chei pentru validare)
 - servere de chei PGP

Certificat Digital PGP

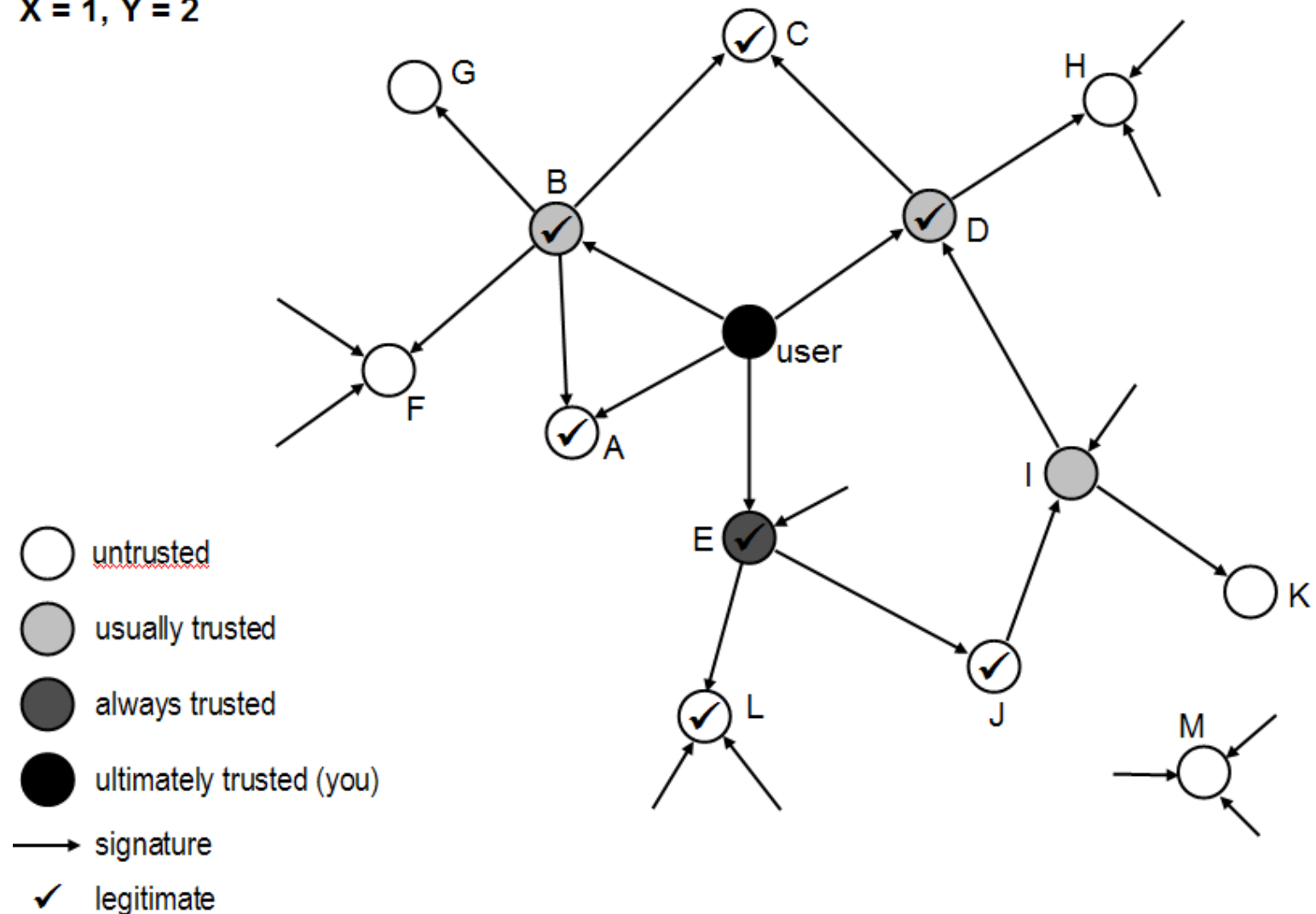


Nivele de încredere

- **încrederea în proprietar (owner trust)**
 - valoare asignată de către fiecare utilizator
 - valori posibile
 - *unknown user*
 - *usually not trusted*
 - *usually trusted (pondere 1/Y)*
 - *always trusted (pondere 1/X)*
 - *ultimately trusted (pondere 1)*
- **încrederea în semnătură (signature trust)**
 - valoare asignată de sistem
 - aceiași cu încrederea în proprietar dacă cheia publică folosită la semnarea recomandării se află în inelul de chei
- **legitimitatea cheii (key legitimacy)**
$$TRUST = SUM(1/X) + SUM(1/Y)$$

Nivele de încredere (cont.)

X = 1, Y = 2



S/MIME

- **Secure / Multipurpose Internet Mail Extension**
- **Standard elaborat de RSA Security**
- **Adăugare facilități de securitate la formatul MIME**
- **Servicii similare PGP (autentificare, confidențialitate, etc.)**
- **IETF RFC 5751, 5750**

RFC 822

- **Definește formatul mesajelor text ce pot fi transmise prin e-mail**
- **Structura unui mesaj RFC 822:**
 - antet (e.g., from: ..., to: ..., cc: ...)
 - corp (textul mesajului)

```
Date: Tue, 03 Dec 2005 10:30:15 (EST)
From: "Ion Bica" <ibica@mta.ro>
Subject: Test
To: afriend@abc.ro
```

```
This is a test.
```

- **RFC 822 are o serie de limitări**
 - nu poate transmite obiecte binare
 - nu oferă suport multilingvistic
 - unele servere SMTP nu acceptă mesaje peste o anumită dimensiune
 - probleme de conversie la nivelul gateway-urilor
- **MIME a fost gândit pentru a elimina aceste neajunsuri**
 - definește noi tipuri de câmpuri pentru antetul mesajelor
 - definește o serie de formate de conținut (standardizarea reprezentării conținutului multimedia)
 - definește reguli de codificare a datelor astfel încât conținutul mesajelor să nu fie modificat de sistemul de mesagerie
 - IETF RFC 2045,...,2049

MIME (cont.)

- **MIME-Version (1.0)**
- **Content-Type**
 - descrie tipul de date din cadrul corpului mesajului
 - pe baza acestui câmp, receptorul poate selecta metoda corespunzătoare pentru afișarea conținutului respectiv
- **Content-Transfer-Encoding**
 - Specifică transformarea folosită pentru a reprezenta corpul mesajului
- **Content-ID**
- **Content-Description**
 - descrie obiectul din cadrul corpului mesajului
 - util atunci când conținutului este indescifrabil (date audio)

MIME (cont.)

From: Nathaniel Borenstein <nsb@bellcore.com>
To: Ned Freed <ned@innosoft.com>
Date: Sun, 21 Mar 1993 23:56:48 -0800 (PST)
Subject: Sample message
MIME-Version: 1.0
Content-type: multipart/mixed; boundary="simple boundary"

This is the preamble. It is to be ignored, though it is a handy place for composition agents to include an explanatory note to non-MIME conformant readers.

--simple boundary

This is implicitly typed plain US-ASCII text. It does NOT end with a linebreak.

--simple boundary

Content-type: text/plain; charset=us-ascii

This is explicitly typed plain US-ASCII text. It DOES end with a linebreak.

--simple boundary--

This is the epilogue. It is also to be ignored.

S/MIME

- **enveloped data** (application/pkcs7-mime; smime-type = enveloped-data)
 - conținut criptat
- **signed data** (application/pkcs7-mime; smime-type = signed-data)
 - semnătură digitală standard (“hash and sign”)
 - conținutul + semnătura sunt codificate base64
 - conținutul nu poate fi interpretat de programe ce nu sunt compatibile S/MIME
- **clear-signed data** (multipart/signed)
 - semnătură digitală standard (“hash and sign”)
 - numai semnătura este codificată base64
 - conținutul poate fi interpretat de programe ce nu sunt compatibile S/MIME; acestea nu vor putea însă să verifice semnătura
- **signed and enveloped data**

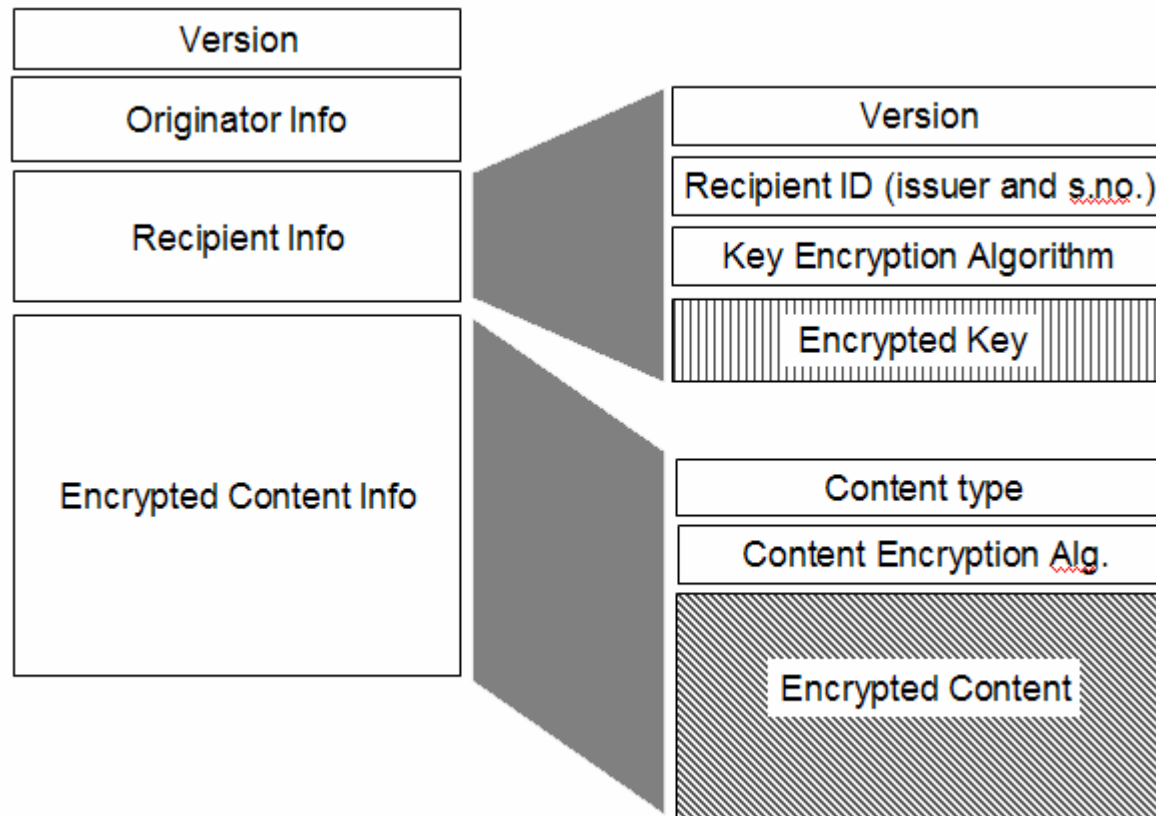
Algoritmi criptografici

- **Funcție hash**
 - must: SHA-1
 - should (receiver): MD5
- **Semnătură digitală**
 - must: DSS
 - should: RSA
- **Anvelopare cheie de sesiune**
 - must: Diffie-Hellman
 - should: RSA
- **Criptare date**
 - sender:
 - should: 3DES, RC2/40
 - receiver:
 - must: 3DES
 - should: RC2/40

Securizare MIME

- Conținutul ce urmează a fi transmis este procesat conform regulilor MIME rezultând un obiect MIME
- Obiectul MIME este procesat de S/MIME pentru a produce un obiect PKCS #7
- Obiectul PKCS #7 este tratat ca și conținut obișnuit (binar) și este încapsulat într-un nou obiect MIME

Criptare date

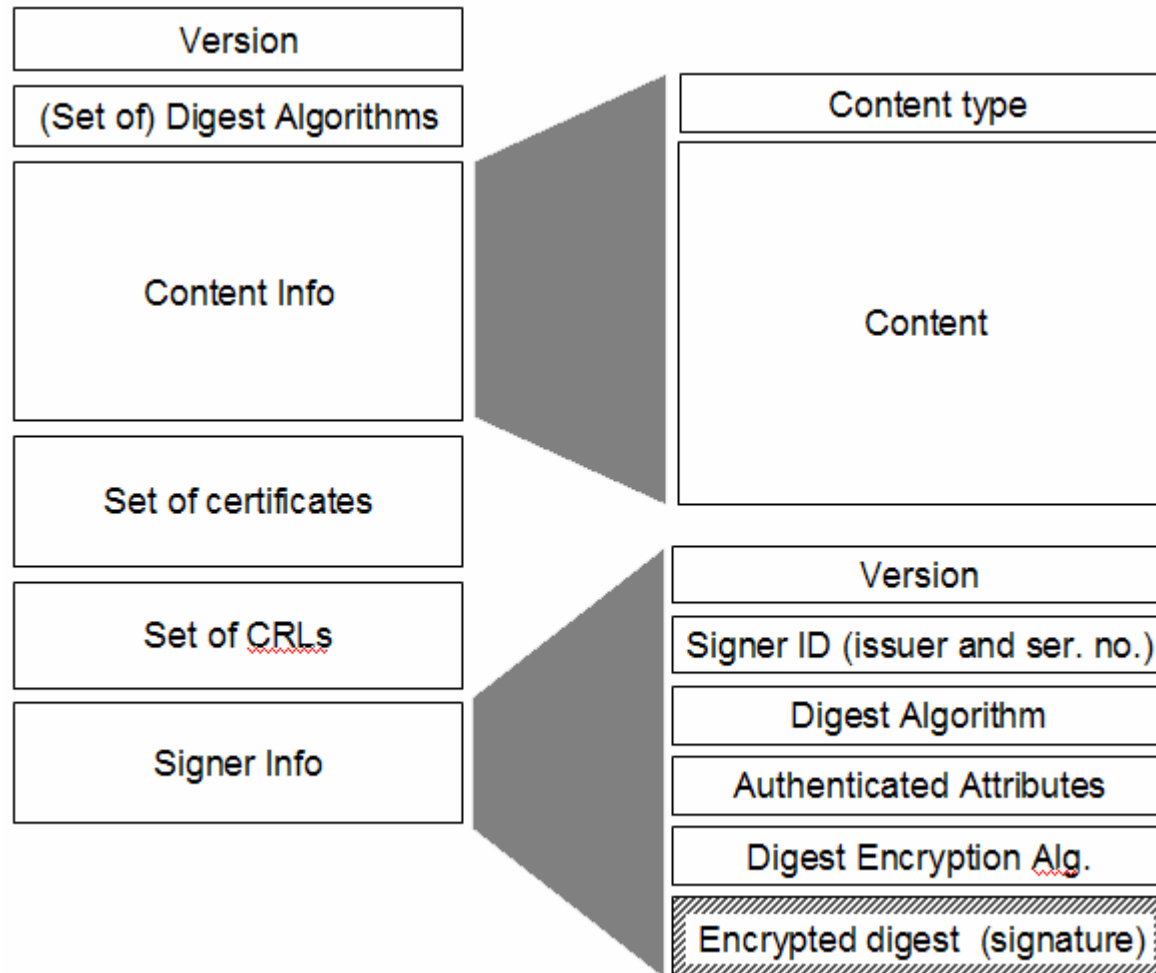


Criptare date (cont)

Content-Type: application/pkcs7-mime;
 smime-type=enveloped-data; name=smime.p7m
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename=smime.p7m

rfvbnj756tbBghyHhHUujhJhjH77n8HHGT9HG4VQpfyF467GhIGf
HfYT67n8HHGghyHhHUujhJh4VQpfyF467GhIGfHfYGTrfvbnjT6j
H7756tbB9Hf8HHGTrfvhJhjH776tbB9HG4VQbnj7567GhIGfHfYT
6ghyHhHUujpfyF40GhIGfHfQbnj756YT64V

Semnare date



Semnare date (cont.)

Content-Type: application/pkcs7-mime;
smime-type=signed-data; name=smime.p7m
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename=smime.p7m

MIAGCSqGSIB3DQEHAqCAMIACAQExCzAJBgUrDgMCGGUAMIAGCSqGSIB3DQEHAQAAMYICNDCCAja
CAQEwgdAwgbwxCzAJBgNVBAYTAkRFMRAwDgYDVQQIEwdIYW1idXJnMRAwDgYDVQQHEwdIYW1idX
JnMTowOAYDVQQKEzFUQyBUcnVzdENlbnRlciBmb3IgaU2VjdXJpdHkgaW4gRGF0YSBOZXR3b3Jrc
YBHbWJIMSIIwIAYDVQQLExlUQyBUcnVzdENlbnRlciBDbGFzcyAyIENBMSSkwJwYJKoZIhvcNAQkB
FhpjZXJ0aWZpY2F0ZUB0cnVzdGNlbnRlci5kZQIPAPBiAAAAAQdEw5SzrwZ8MAkGBSsOAwIaBQC
ggbowGAYJKoZIhvcNAQkDMQsGCSqGSIB3DQEHAATACBgkqhkiG9w0BCQUxDxcNMDUxMjAzMDIxMz
A3WjAjBgkqhkiG9w0BCQQxFgQU/ItNf+rqvXbwVlG/Ewy8O3r8cbMwWwYJKoZIhvcNAQkPMU4wT
DAKBggqhkiG9w0DBzAOBggqhkiG9w0DAGICAIAwDQYIKoZIhvcNAwICAUAwBwYFKw4DAgcwDQYI
KoZIhvcNAwICASgwBwYFKw4DAh0wDQYJKoZIhvcNAQEBBQAEgYBN76JiXrLSwOlTCQFZlrO0MAH
sfsJcxLOxYcGiuDTm3y2Vo2y+tfZZLUG032n32ouT1he8KaecphMT3nezUaBAVif74rel4fP/wr
ACFa69Wyk7q0NsVZ7sCta5Pg6H4o/LC+oEsr4VGxYYvl28VJ30eJtyBHfYzqfLJ2IMsEY1cQAAA
AAAAA==

Semnare date (cont.)

```
Content-Type: multipart/signed;  
    protocol="application/pkcs7-signature";  
    micalg=sha1; boundary=boundary42
```

```
--boundary42
```

```
Content-Type: text/plain
```

```
This is a clear-signed message.
```

```
--boundary42
```

```
Content-Type: application/pkcs7-signature; name=smime.p7s
```

```
Content-Transfer-Encoding: base64
```

```
Content-Disposition: attachment; filename=smime.p7s
```

```
ghyHhHUujhJhjH77n8HHGTrfvbnj756tbB9HG4VQpfyF467GhIGfHfYT6  
4VQpfyF467GhIGfHfYT6jH77n8HHGghyHhHUujhJh756tbB9HGTrfvbnj  
n8HHGTrfvhJhjH776tbB9HG4VQbnj7567GhIGfHfYT6ghyHhHUujpfyF4  
7GhIGfHfYT64VQbnj756
```

```
--boundary42--
```

Configurare S/MIME

- **Clienți de e-mail compatibili S/MIME v3!**
 - Outlook, Outlook Express, Thunderbird
- **Toate setările se fac la nivelul clienților**
- **Banner-ele și disclaimer-ele adăugate automat de către serverele de mail sau antivirus invalidează semnăturile digitale!**

Atacuri împotriva PGP și S/MIME

■ EFAIL (Mai 2018) !!!

- exfiltrare conținut mesaj criptat
- presupune interceptarea și modificarea mesajului criptat
- Direct exfiltration attack
- CBC/CFB gadget attack
- mai multe detalii la: <https://efail.de/>

■ Soluții

- verificarea strictă a integrității mesajelor criptate
- dezactivarea redării resurselor externe în mod implicit
- schimbarea modului de redare a mesajelor HTML



5. Standarde de Securitate



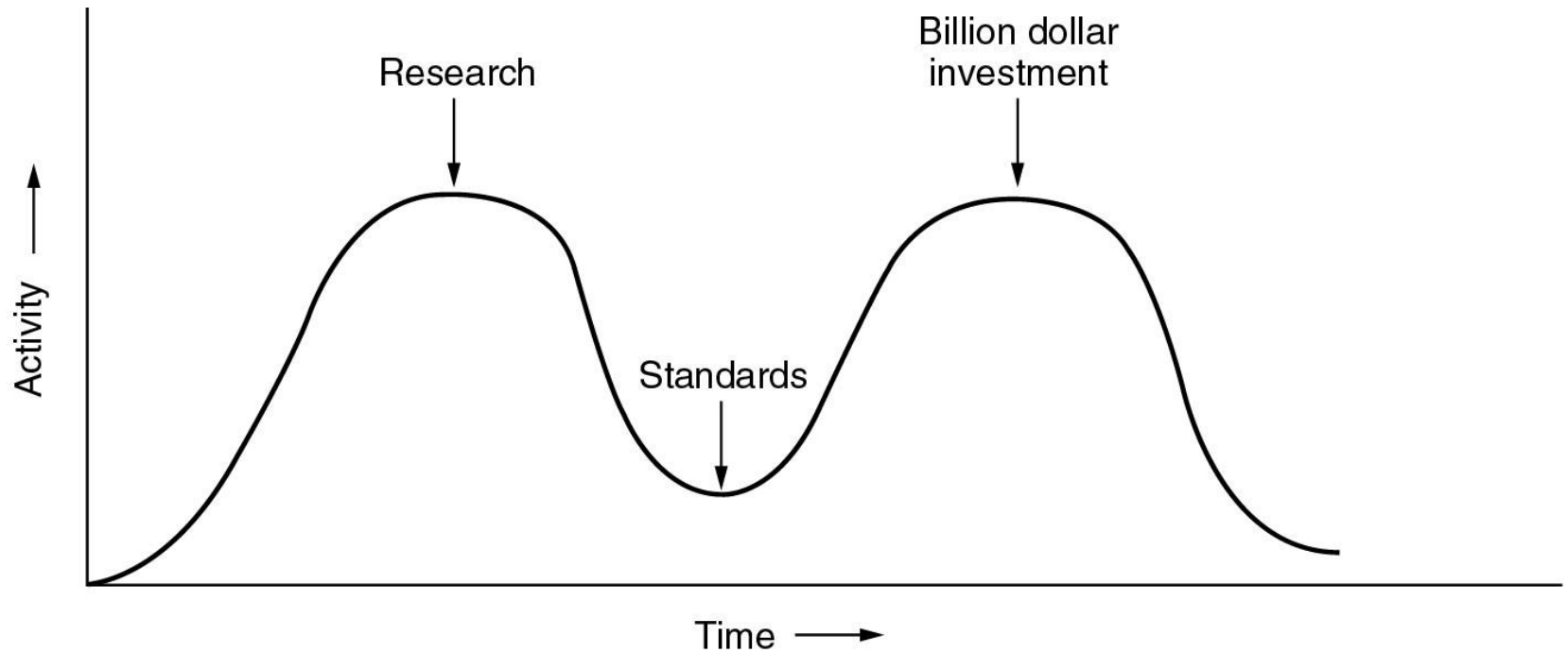
Standarde de securitate

- Rolul standardelor:
 - asigurarea interoperabilității
- Tipuri de standarde
 - *de jure* (FIPS, ANSI, etc.)
 - *de facto* (PKCS, etc.)

“The nice things about standards is that you have so many to choose from”

Andrew Tanenbaum

Standarde de securitate (cont.)



**Apocalipsa celor doi elefanți
(David Clark, MIT)**

Organizații de standardizare

- **Internet Society**
 - Internet Architecture Board (IAB)
 - Internet Engineering Task Force (IETF)
 - Internet Engineering Steering Group (IESG)
 - Draft -> Request for Comment (RFC) -> Standard
- **International Telecommunication Union (ITU)**
 - ITU-R (Radiocommunications Sector)
 - ITU-T (Telecommunications Sector) - CCITT
 - ITU-D (Development Sector)
- **Institute of Electrical and Electronics Engineers (IEEE)**
- **European Telecommunications Standards Institute (ETSI)**
- **European Committee for Standardization (CEN)**
- **International Standards Organization (ISO)**
- **National Standards Organization**
 - ANSI (US), BSI (GB), AFNOR (FR), DIN (GE), etc.

Organizații de standardizare (cont.)

- **National Institute of Standards and Technology (NIST)**
- **RSA Laboratories**
 - Public Key Cryptography Standards
- **World Wide Web Consortium (W3C)**
 - XML Signature WG
 - XML Encryption WG
 - XML Key Management WG
- **The OpenGroup (IBM, HP, SUN, NEC, Fujitsu)**
 - Common Data Security Architecture (CDSA)
- **Organization for the Advancement of Structured Information Standards (OASIS)**
 - Security Assertion Markup Language (SAML)
- **PC/SC Workgroup (Gemplus, Axalto, Infineon)**
 - Smart card
- **EMV (Europay, Mastercard, VISA)**
 - Carduri bancare

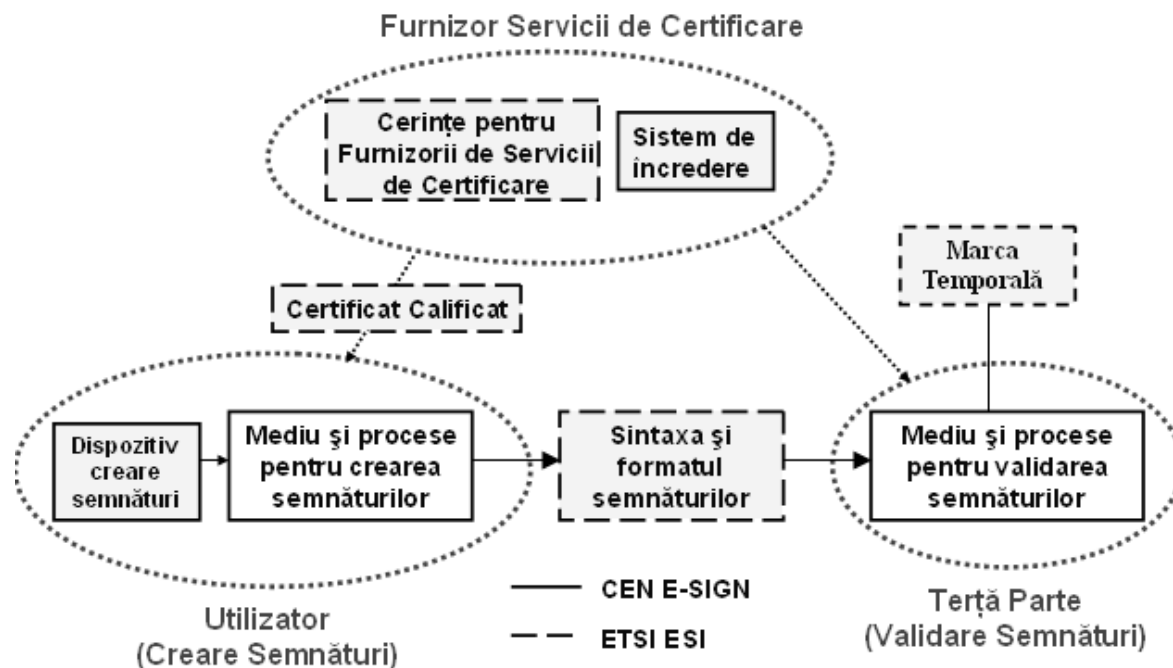
IETF – Grupuri de lucru active pe security

- **ace** Authentication and Authorization for Constrained Environments
- **acme** Automated Certificate Management Environment
- **curdle** CURves, Deprecating and a Little more Encryption
- **dots** DDoS Open Threat Signaling
- **i2nsf** Interface to Network Security Functions
- **ipsecme** IP Security Security Maintenance and Extensions
- **kitten** Common Authentication Technology Next Generation
- **lamps** Limited Additional Mechanisms for PKIX and SMIME
- **mile** Managed Incident Lightweight Exchange
- **oauth** Web Authorization Protocol
- **sacm** Security Automation and Continuous Monitoring
- **secevent** Security Events
- **tls** Transport Layer Security
- **tokbind** Token Binding
- **trans** Public Notary Transparency

- [X.273] Recommendation X.273 - Information technology - Open Systems Interconnection - Network layer security protocol
- [X.274] Recommendation X.274 - Information technology - Telecommunication and information exchange between systems - transport layer security protocol
- **[X.509] Recommendation X.509 - Information technology - Open Systems Interconnection - The directory: Authentication framework**
- [X.736] Recommendation X.736 - Information technology - Open Systems Interconnection - Systems management: Security alarm reporting function
- [X.736 SUMMARY] Summary of Recommendation X.736 - Information technology - open systems interconnection - systems management: security alarm reporting function
- [X.740] Recommendation X.740 - Information technology - Open Systems Interconnection - systems management: security audit trail function
- [X.800] Recommendation X.800 - Security architecture for Open Systems Interconnection for CCITT applications
- [X.800 SUMMARY] Summary of Recommendation X.800 - Security architecture for open systems interconnection for CCITT applications
- [X.802] Recommendation X.802 - Information technology - Lower layers security model
- [X.803] Recommendation X.803 - Information Technology - Open Systems Interconnection - Upper layers security model

- **Standard Specifications for Public-Key Cryptography (P1363)**
- **IEEE 802.1x: Standard for port-based Network Access Control (PNAC)**
- **IEEE 802.11i: Standard for Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) specifications - Amendment 6: Medium Access Control (MAC) Security Enhancements**

- European Electronic Signature Standardization Initiative
 - Standardizarea semnăturilor electronice
- ETSI ESI
- CEN/ISSS



- peste 50 de standarde
- TS 101 862 Qualified Certificate Profile
- TS 101 733 Electronic Signature Formats
- TS 101 903 XML Advanced Electronic Signatures (XAdES)
- TS 101 456 Policy requirements for Certification Authorities issuing Qualified Certificates
- SR 002 176 Algorithms and Parameters for Secure Electronic Signatures
- TS 101 861 Time stamping profile
- TS 102 023 Policy requirements for time-stamping authorities
- TR 102 272 ASN.1 format for signature policies
- ...

- peste 20 de standarde
- **CWA 14167 Security Requirements for Trustworthy Systems
Managing Certificates for Electronic Signatures (Part 1,2,3,4)**
- **CWA 14169 Secure Signature-creation devices "EAL 4+"**
- **CWA 14170 Security requirements for signature creation applications**
- **CWA 14171 General guidelines for electronic signature verification**
- **CWA 14172 EESSI Conformity Assessment Guidance (Part 1,2,3,4,5,6,7,8)**
- **CWA 14355 Guidelines for the implementation of Secure Signature-Creation Devices**
- **CWA 14365 Guide on the Use of Electronic Signatures (Part 1,2)**
- **CWA 14890 Application Interface for smart cards used as Secure Signature Creation Devices (Part 1,2)**
- ...

- **ISO/IEC Frameworks:**
 - ISO/IEC 7498-2: Open Systems Interconnect (OSI) Security Model
 - ISO/IEC 9797: Message Authentication Codes (MACs)
 - ISO/IEC 10181: Security Frameworks
 - ISO/IEC 10736: Transport Layer Security Protocol (TLSP)
 - ISO/IEC 11577: Network Layer Security Protocol (NLSP)
 - ISO/IEC 11770: Key Management
 - ISO/IEC 13888: Non-Repudiation
- **ISO/IEC Cryptographic Mechanisms:**
 - ISO/IEC 9796: Digital Signature Scheme giving Message Recovery
 - ISO/IEC 10116: Modes of Operation for an n-bit Block Cipher
 - ISO/IEC 10118: Hash Functions
 - ISO/IEC 14888: Digital Signatures with Appendix
 - ISO/IEC 15946: Information Technology - Security Techniques – Cryptographic techniques based on elliptic curves

ISO (cont.)

- **ISO/IEC 27000 Series:**

- **ISO/IEC 27000: Information security management systems - Overview and vocabulary**
- **ISO/IEC 27001: Information technology - Security Techniques - Information security management systems - Requirements.**
- **ISO/IEC 27002: Code of practice for information security management**
- **ISO/IEC 27003: Information security management system implementation guidance**
- **ISO/IEC 27004: Information security management - Monitoring, measurement, analysis and evaluation**
- **ISO/IEC 27005: Information security risk management**

ANSI

- **ANSI X9.23: Data Encryption Standard**
- **ANSI X9.26: Secure Sign-On**
- **ANSI X9.30: Digital Signature Standard**
- **ANSI X9.31: RSA**
- **ANSI X9.41: Security Services Management**
- **ANSI X9.42: Diffie-Hellman Key Agreement**
- **ANSI X9.43: Key Archiving and Retrieval**
- **ANSI X9.57: Certificate Management**
- **ANSI X9.62: Elliptic Curve Digital Signature Algorithm**

- **FIPS Pub 46-2: Data Encryption Standard**
- **FIPS Pub 81: DES Modes of Operation**
- **FIPS Pub 112: Standard on Password Usage**
- **FIPS Pub 140: Security Requirements for Cryptographic Modules**
- **FIPS Pub 180: Secure Hash Standard**
- **FIPS Pub 185: Escrowed Encryption Standard**
- **FIPS Pub 186: Digital Signature Standard (DSS)**
- **FIPS Pub 197: Advanced Encryption Standard (AES)**
- **FIPS Pub 198: The Keyed-Hash Message Authentication Code (HMAC)**

RSA Labs

- PKCS #1: RSA Cryptography Standard
- PKCS #3: Diffie-Hellman Key Agreement Standard
- PKCS #5: Password-Based Cryptography Standard
- PKCS #6: Extended-Certificate Syntax Standard
- **PKCS #7: Cryptographic Message Syntax Standard**
- PKCS #8: Private-Key Information Syntax Standard
- PKCS #9: Selected Attribute Types
- PKCS #10: Certification Request Syntax Standard
- PKCS #11: Cryptographic Token Interface Standard
- PKCS #12: Personal Information Exchange Syntax Standard
- PKCS #13: Elliptic Curve Cryptography Standard
- PKCS #15: Cryptographic Token Information Format Standard

